

Abdul Wahid

EC-Council CND (Certified Network Defender)

Vulnerability Management & Risk Anticipation – OSSIM, OWASP ZAP, OpenSCAP/SCC & Nessus

Executive Summary

Risks that stay hidden eventually become incidents.

Module 18 flips the script from reaction to anticipation. In a controlled lab (OSSIM Server 192.168.100.75, Admin Machine 192.168.100.138, Web Server 192.168.100.145), students systematically uncover and manage vulnerabilities before attackers can exploit them.

The journey begins with AlienVault OSSIM: the Web Server is added as an asset, a HIDS agent is deployed, credentials are created, and a full vulnerability scan is executed and analyzed. Next, OWASP ZAP performs deep application-level scanning — spidering the site and running active tests to expose web vulnerabilities. OpenSCAP then brings compliance-focused scanning to the Windows Server using the SCAP Compliance Checker, delivering clear configuration and security baseline results. Finally, Nessus provides professional-grade vulnerability analysis, completing a multi-tool arsenal for risk identification.

Result: complete, hands-on mastery of proactive vulnerability management across SIEM, web application, compliance, and commercial scanners — the exact skills needed to anticipate and reduce risk before it becomes a breach.

Contents

Virtual Machine & Network Setup 4

Vulnerability Management using OSSIM 5

Access OSSIM Web Interface 7

Adding Web Server as an Asset 8

Configure the Asset 10

Deploy HIDS Agent 11

Restart HIDS Service 12

Create Credentials for Vulnerability Scan 14

Create and Run Vulnerability Scan Job 16

Application Vulnerability Scanning using OWASP ZAP 18

Setup & Install OWASP ZAP 19

Launch OWASP ZAP 20

Perform Automated Scan 21

Review Spider and Active Scan Results 22

Vulnerability Management of Windows Server using OpenSCAP 26

Prepare the Web Server 27

Install SCAP Compliance Checker (SCC) 28

Configure and Run the Scan 29

View the Results 31

Vulnerability Analysis Using the Nessus 36

Access Nessus 38

Virtual Machine & Network Setup

Gateway: 192.168.100.2

Machine	IP Address	Role
OSSIM Server	192.168.100.75	AlienVault OSSIM (SIEM + Vulnerability)
Admin Machine	192.168.100.138	Management / Tool installation machine
Web Server	192.168.100.145	Target machine (to be scanned)

Vulnerability Management using OSSIM

(Risk Anticipation with Risk Management)

Use AlienVault OSSIM to discover assets, deploy HIDS agents, create credentials, and perform a vulnerability scan on the Web Server. Analyze the results and generate a detailed report.

Objective:

Access OSSIM web interface

Add and configure the Web Server as an asset

Deploy HIDS agent on the Web Server

Create and test credentials for vulnerability scanning

Run a full vulnerability scan

View and export the vulnerability report

Machines Required

Machine	IP Address	Role
OSSIM Server	192.168.100.75	AlienVault OSSIM (SIEM + Vulnerability)
Admin Machine	192.168.100.138	Access OSSIM web interface
Web Server	192.168.100.145	Target asset to be scanned

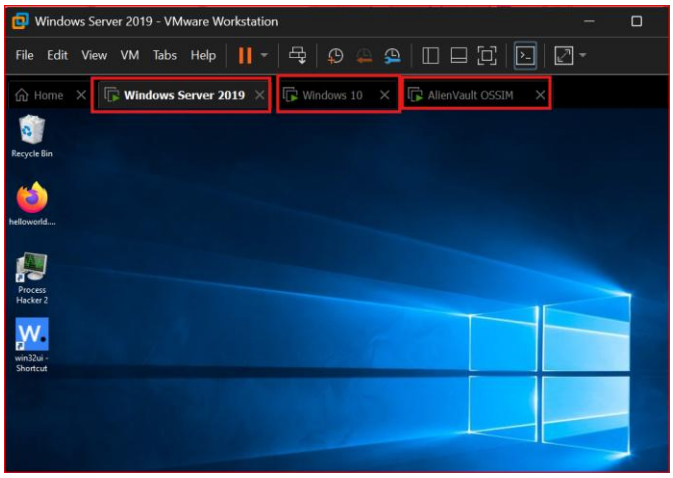
Network: All machines on VMnet3 (NAT) – Gateway 192.168.100.2

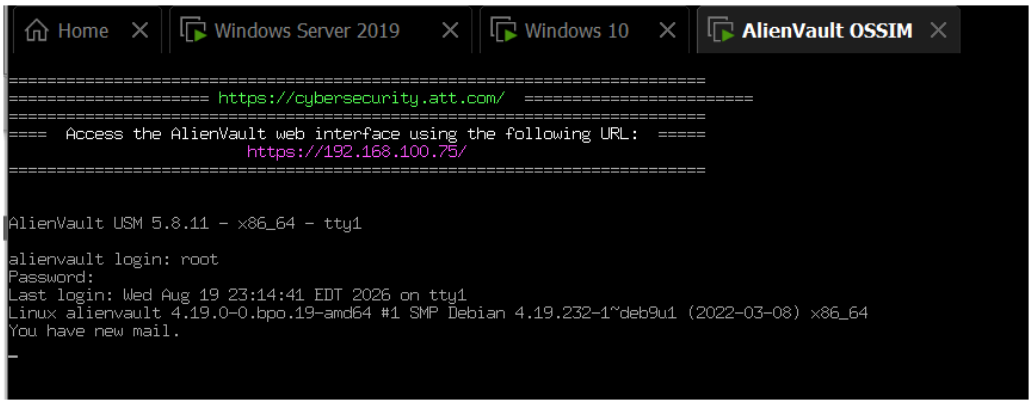
Tools Required

Tool	Purpose
AlienVault OSSIM	SIEM + Vulnerability Management platform
Google Chrome / Edge	Access OSSIM web interface

Launch Required Machines

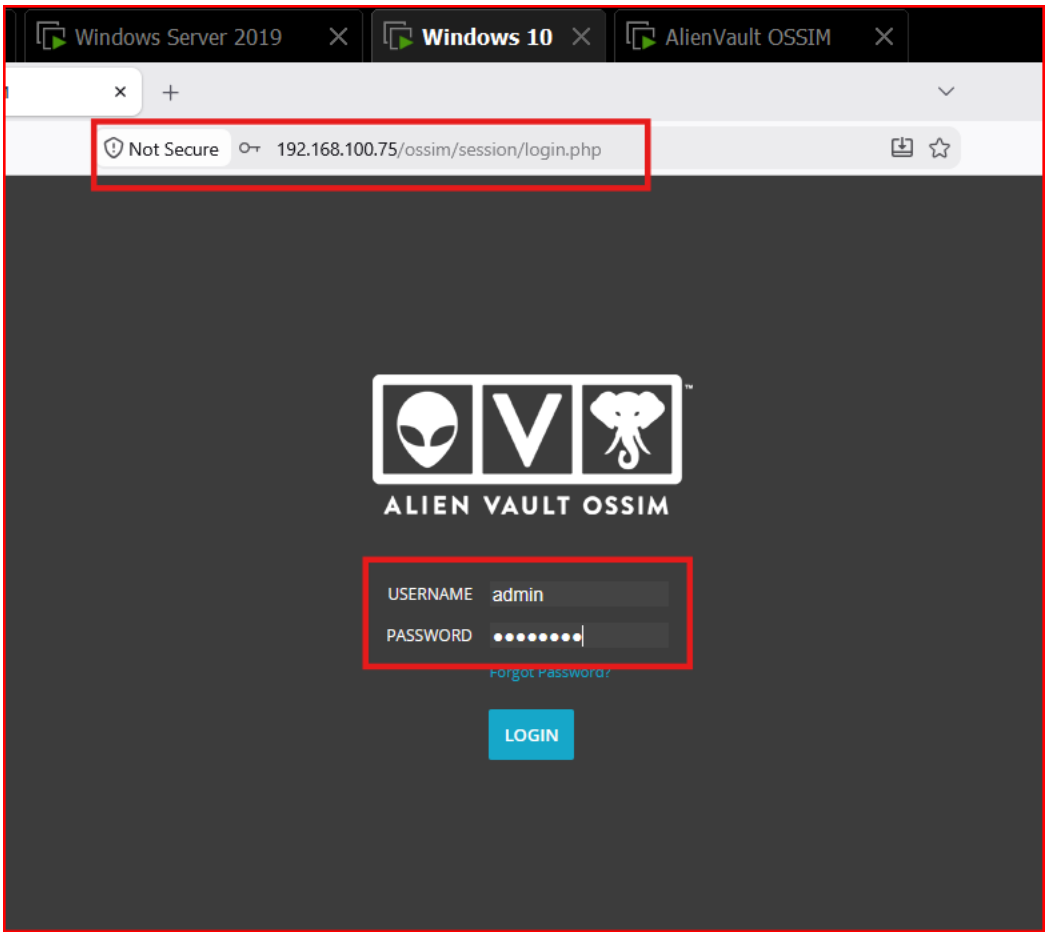
1. Start **OSSIM Server** VM
2. Start **Web Server** VM
3. Start **Admin Machine** VM





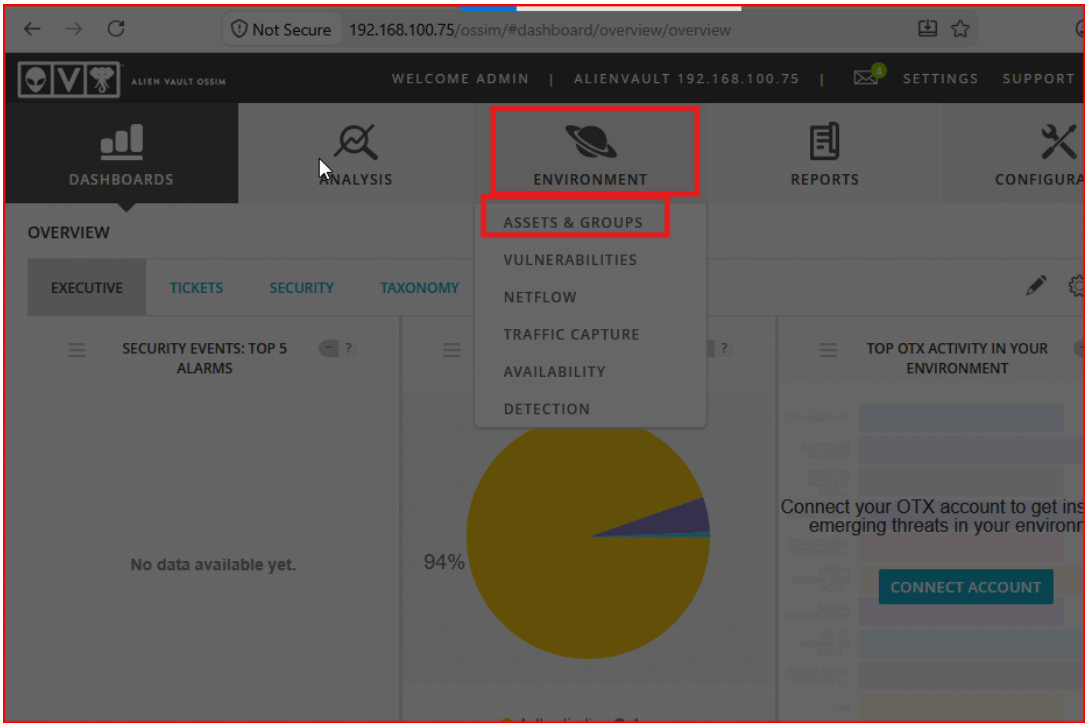
Access OSSIM Web Interface

1. On **Admin Machine**, open Google Chrome.
2. Go to: https://192.168.100.75
3. Click **Advanced → Proceed to 192.168.100.75 (unsafe)**.
4. Login with:
    - Username: admin
    - Password: Admin123
5. Click **Skip AlienVault Wizard** (bottom left).
6. If any "Help us improve" popup appears → click **Cancel**.

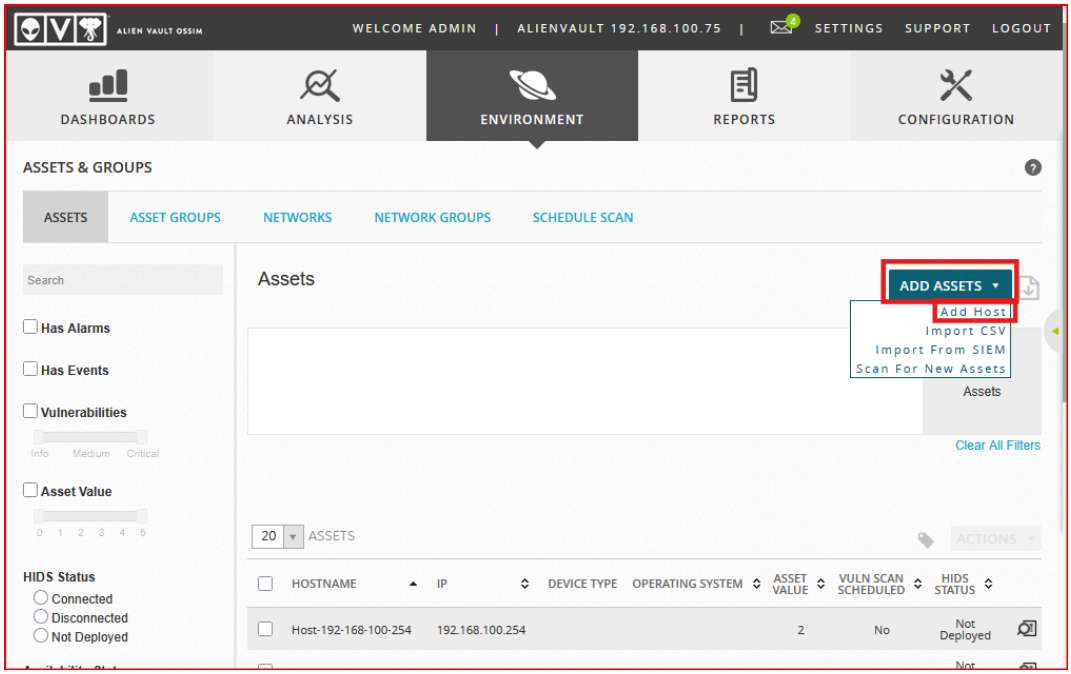


Adding Web Server as an Asset

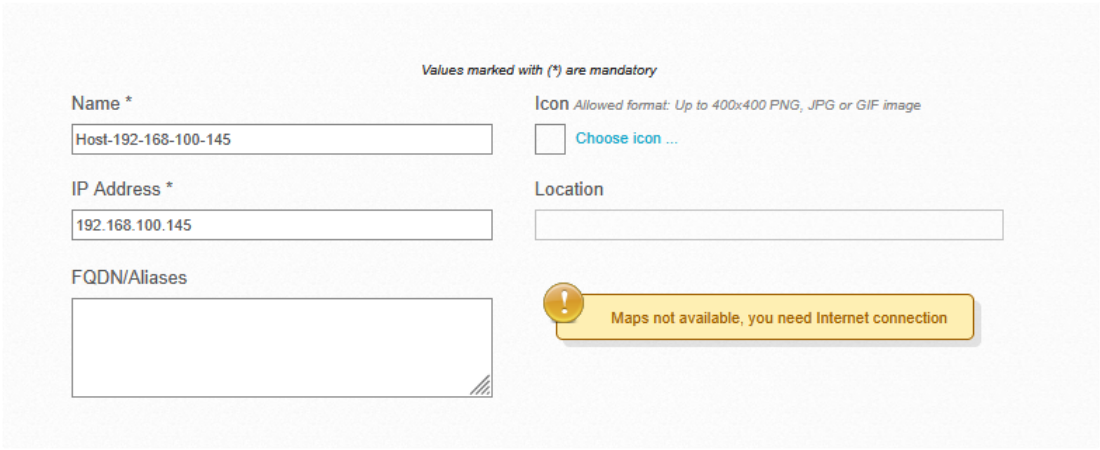
1. Go to **ENVIRONMENT → ASSETS & GROUPS**.



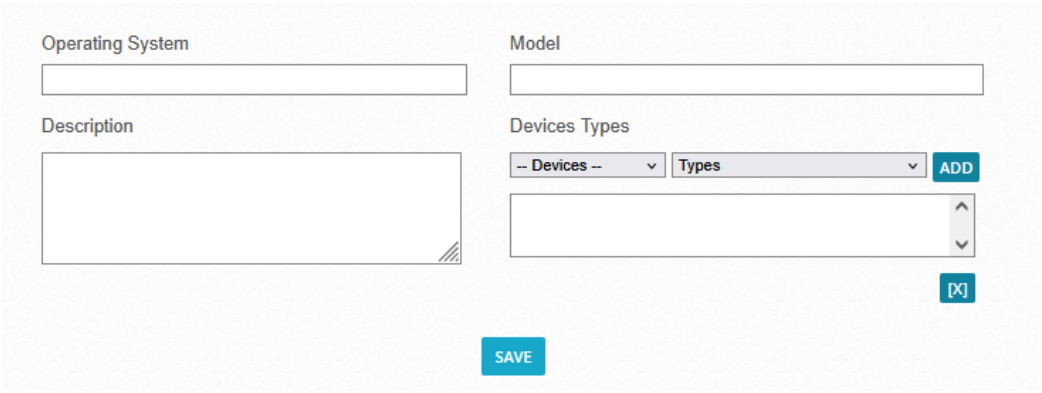
2. Click **ADD ASSETS → Add Host**.



3. Fill the details:
    - **Name**: Host-192-168-100-145
    - **IP Address**: 192.168.100.145

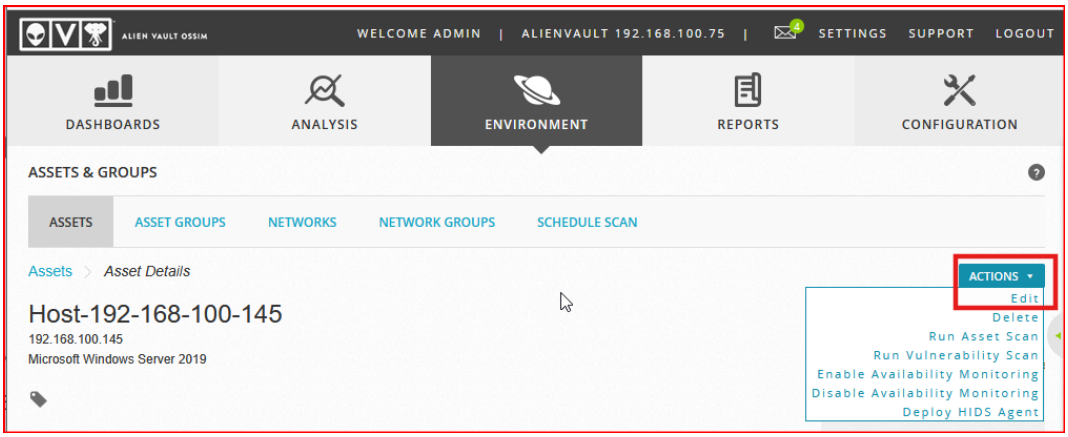


4. Click **Save**.

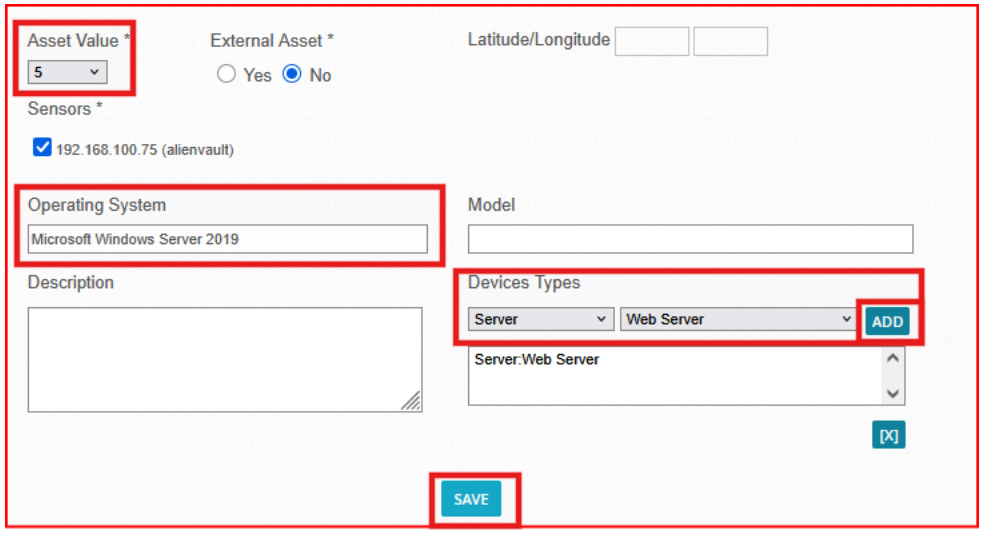


Configure the Asset

1. Check the checkbox next to Host-192.168.100.145.
2. Click **ACTIONS → Edit**.

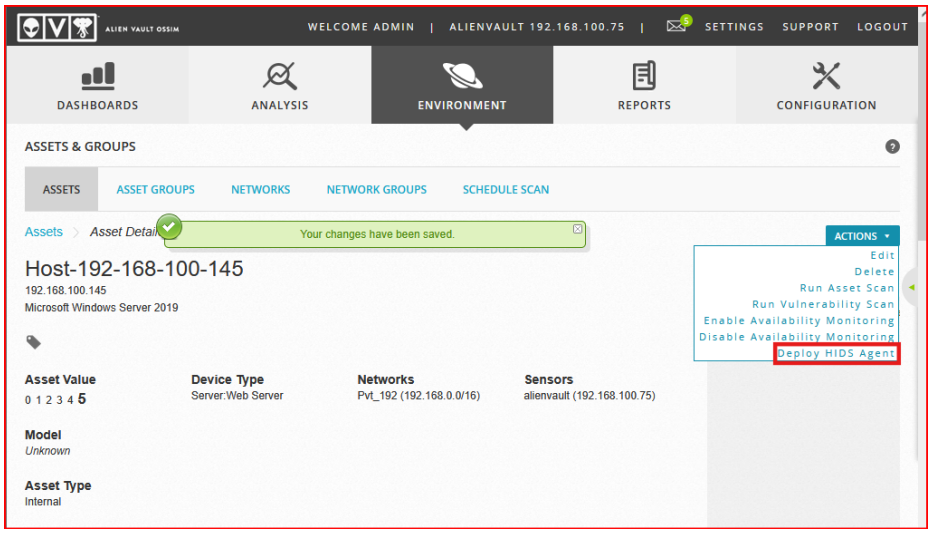


3. Set the following:
   - **Asset Value**: 5
   - **Operating System**: Microsoft Windows Server 2019 (or 2016)
   - **Device Type**: Server → Web Server (click **Add**)
4. Click **Save**.

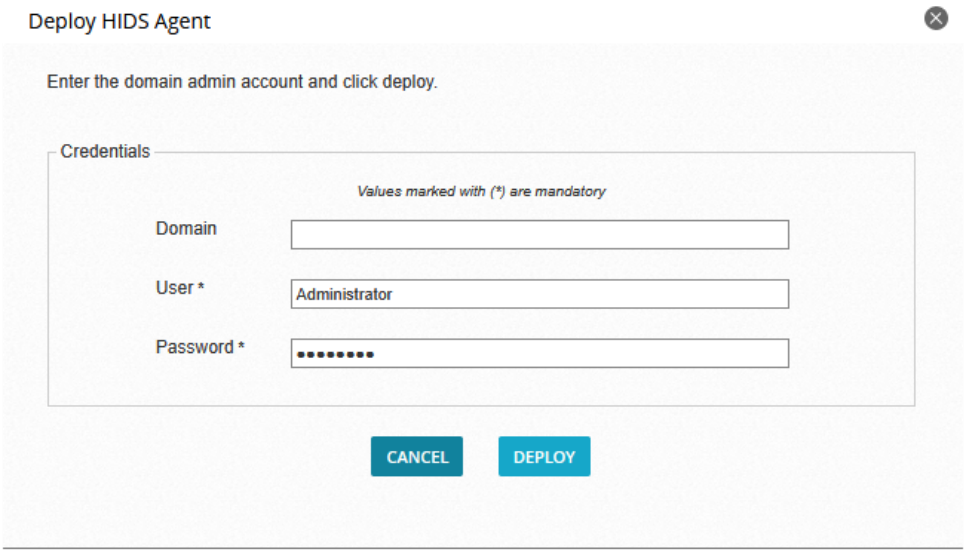


Deploy HIDS Agent

1. Again, check Host-192.168.100.145.
2. Click **ACTIONS → Deploy HIDS Agents**.

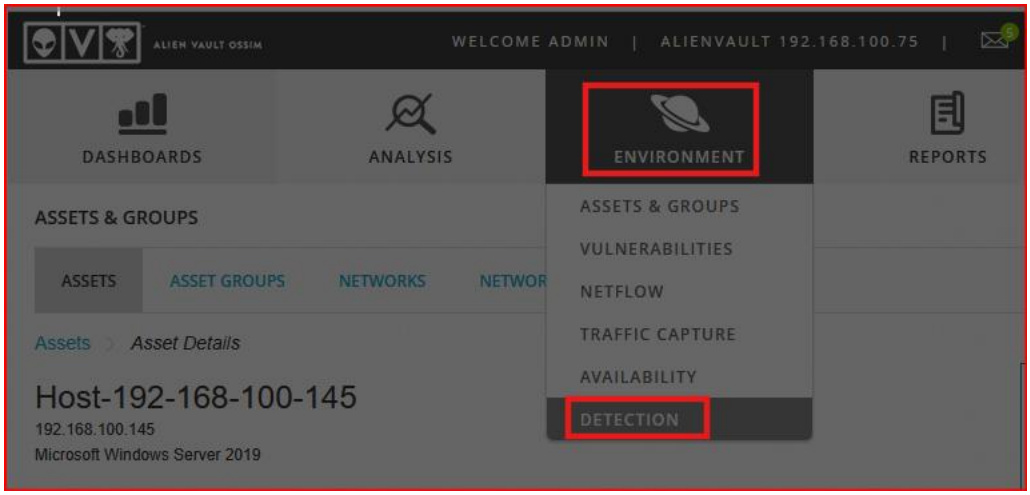


3. Enter credentials:
    - User: Administrator
    - Password: Admin123
4. Click **Deploy**.
5. Wait until the process finishes.



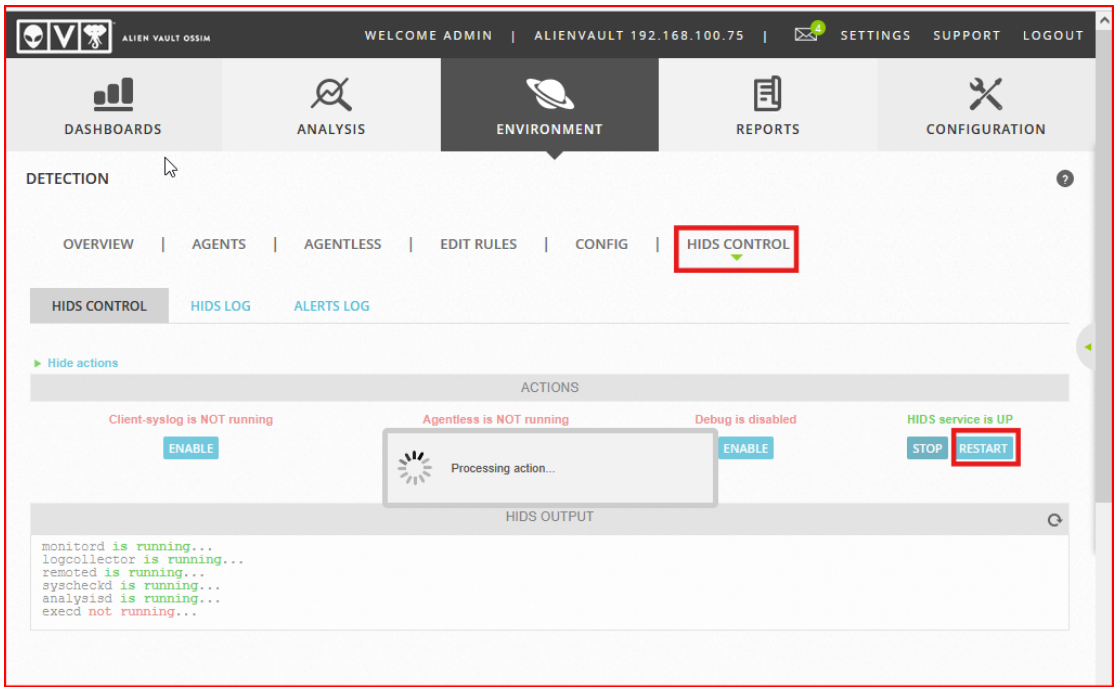
Restart HIDS Service

1. Go to **ENVIRONMENT → DETECTION**.

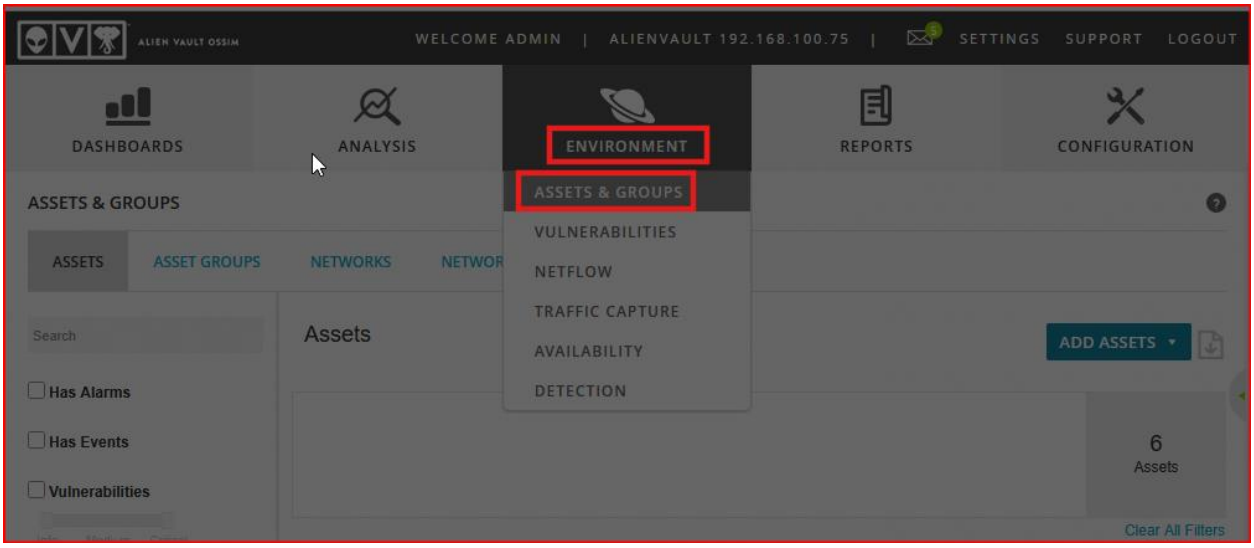


2. Click **HIDS CONTROL** tab.

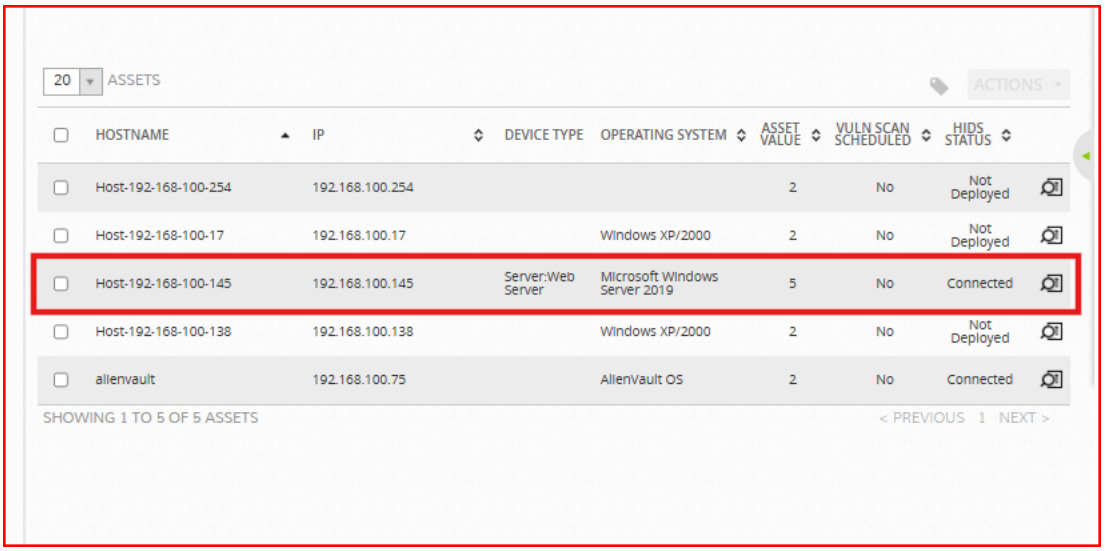
3. Under **ACTIONS**, click **RESTART**.



4. Go back to **ENVIRONMENT → ASSETS & GROUPS**.

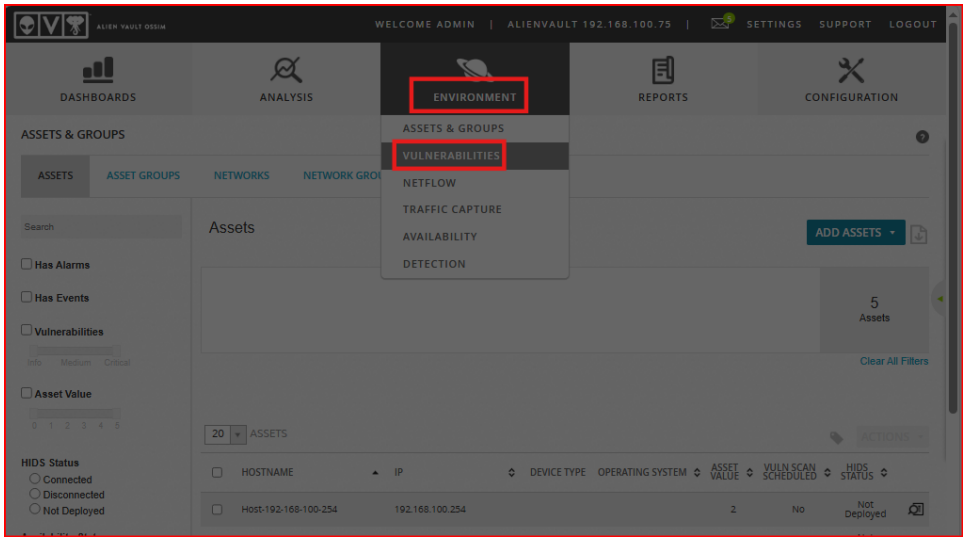


5. Confirm that **HIDS STATUS** of Host-192.168.100.145 shows **Connected**.

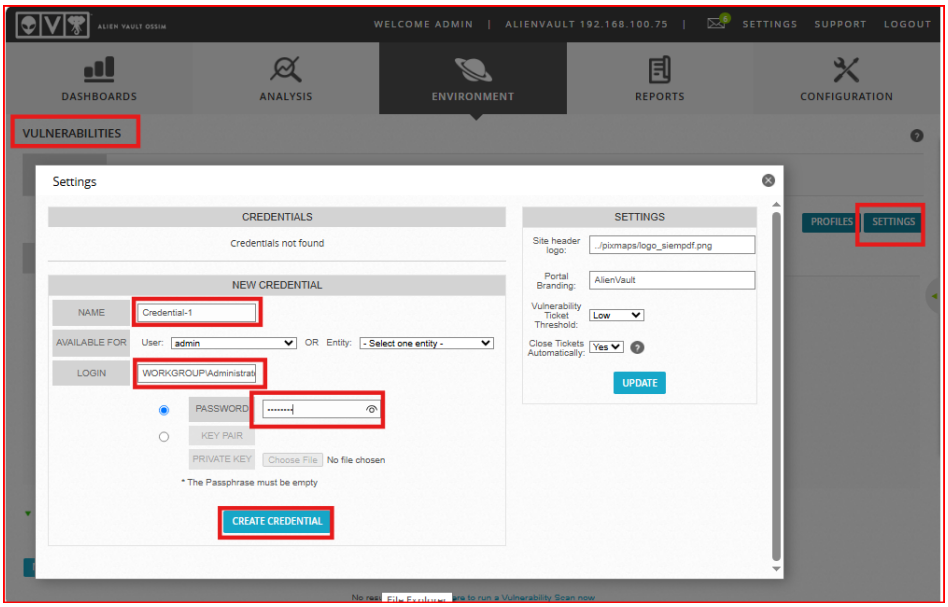


Create Credentials for Vulnerability Scan

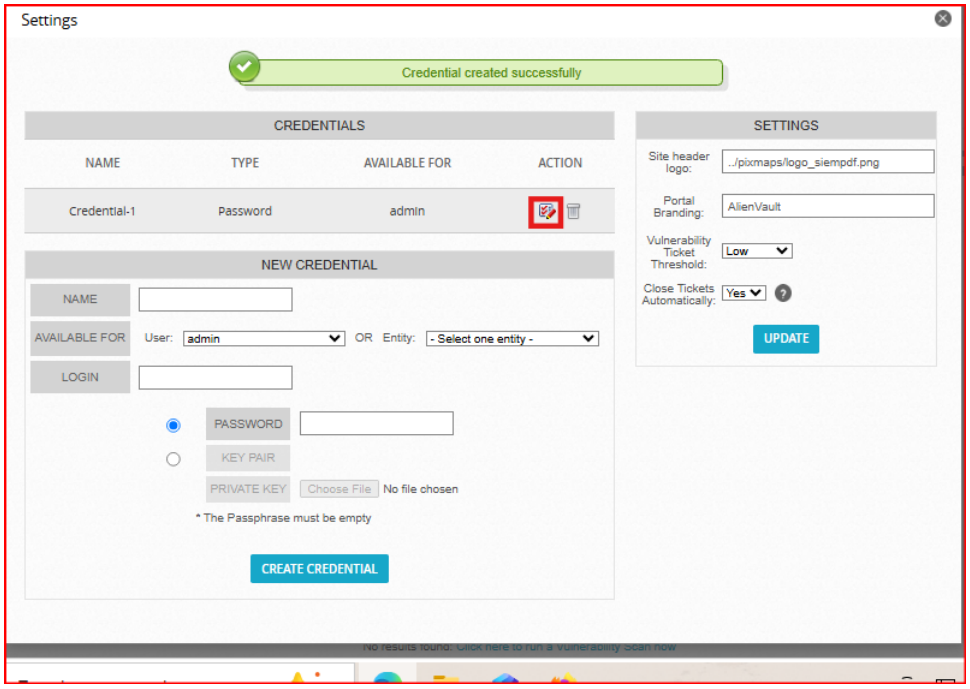
1. Go to **ENVIRONMENT → VULNERABILITIES**.



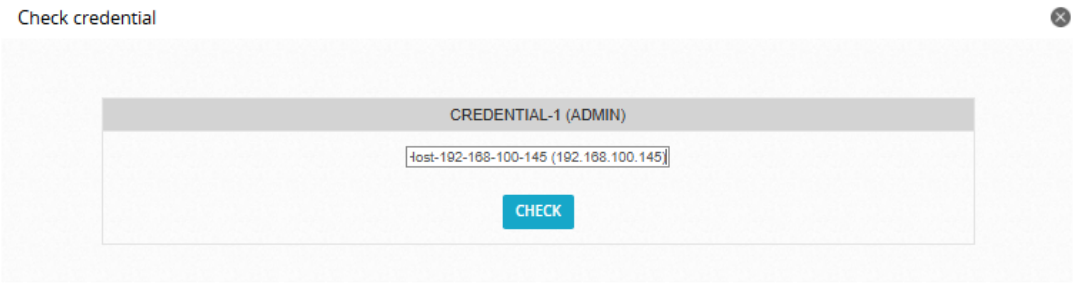
2. Click **SETTINGS** (top right).
3. Under **NEW CREDENTIAL**, fill:
    - **Name**: Credential-1
    - **Login**: WORKGROUP\Administrator
    - Select **PASSWORD** and type: Admin123
4. Click **CREATE CREDENTIAL**.



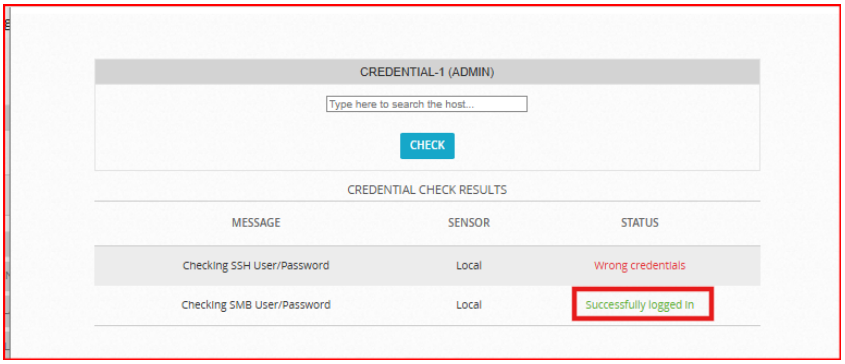
5. Click the **Check Credential** icon next to Credential-1.



6. Type: Host-192.168.100.145 (192.168.100.145) → click **CHECK**.

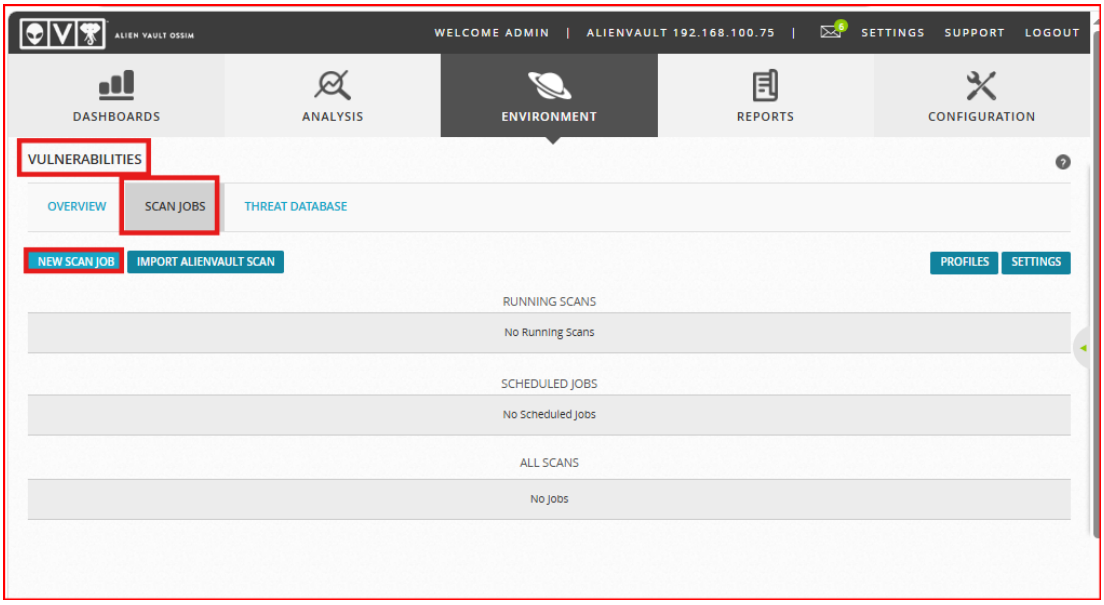


7. Confirm status shows **Successfully logged in**.
8. Close the windows.

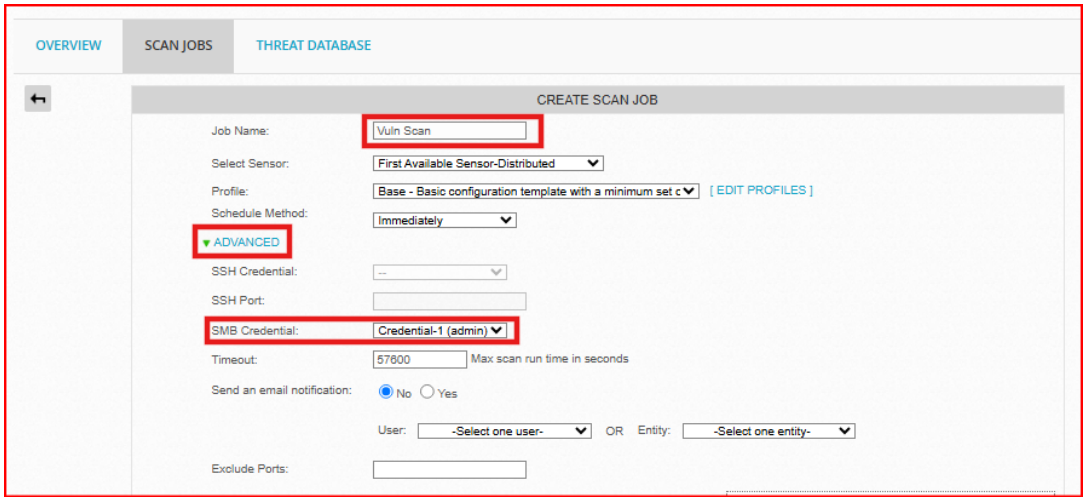


Create and Run Vulnerability Scan Job

1. Go to **ENVIRONMENT → VULNERABILITIES → SCAN JOBS**.
2. Click on **NEW SCAN JOB**.

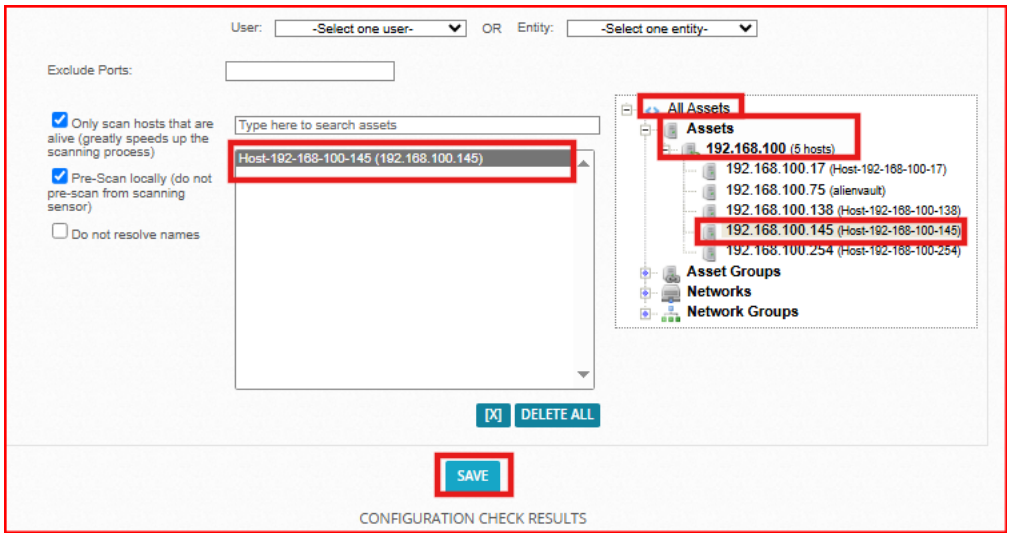


3. Fill out the details:
   - **Job Name**: Vuln Scan
   - Expand **ADVANCED** → set **SMB Credential**: Credentials1 (admin)



Expand **All Assets** → **Assets** → **192.168.100** → select 192.168.100.145

4. Click **Save**.



5. Wait until the scan status changes to **Completed** (this can take 15–30 minutes).

View the Report

1. Once the scan is **Completed**, double-click on the job name **Vulnerability Scan**.
2. You will see the vulnerability pie chart and summary.
3. Alternatively, click the **PDF** icon in the **ACTION** column to download a detailed report.

You have successfully performed vulnerability management using AlienVault OSSIM.

Key Achievements:

- Added and configured the Web Server as a high-value asset
- Deployed HIDS agent for host-based detection
- Created and verified credentials
- Ran a full vulnerability scan
- Generated and analyzed the vulnerability report

This demonstrates how a network defender can discover assets, monitor them, and identify vulnerabilities using an open-source SIEM platform.

Application Vulnerability Scanning using OWASP ZAP

(Risk Anticipation with Risk Management)

Use **OWASP ZAP** (Zed Attack Proxy) to perform Dynamic Application Security Testing (DAST) on the LuxuryTreats website hosted on the Web Server, discover vulnerabilities, and generate a detailed report.

Objective:

Launch OWASP ZAP

Perform Automated Scan on the website

Spider the application to discover pages

View Active Scan results and Alerts

Analyze vulnerabilities

Generate and save an HTML report

Machines Required

Machine	IP Address	Role
Admin Machine	192.168.100.138	Run OWASP ZAP
Web Server	192.168.100.145	Hosts the target website

Tools Required

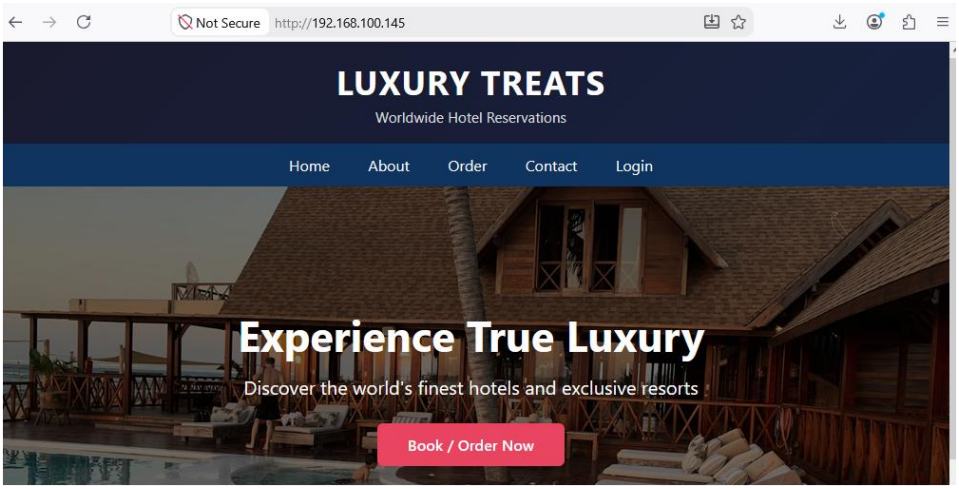
Tool	Purpose
OWASP ZAP	Web application vulnerability scanner (DAST)

Note: OWASP ZAP should already be installed on the Admin Machine (Desktop shortcut).

Launch Required Machines

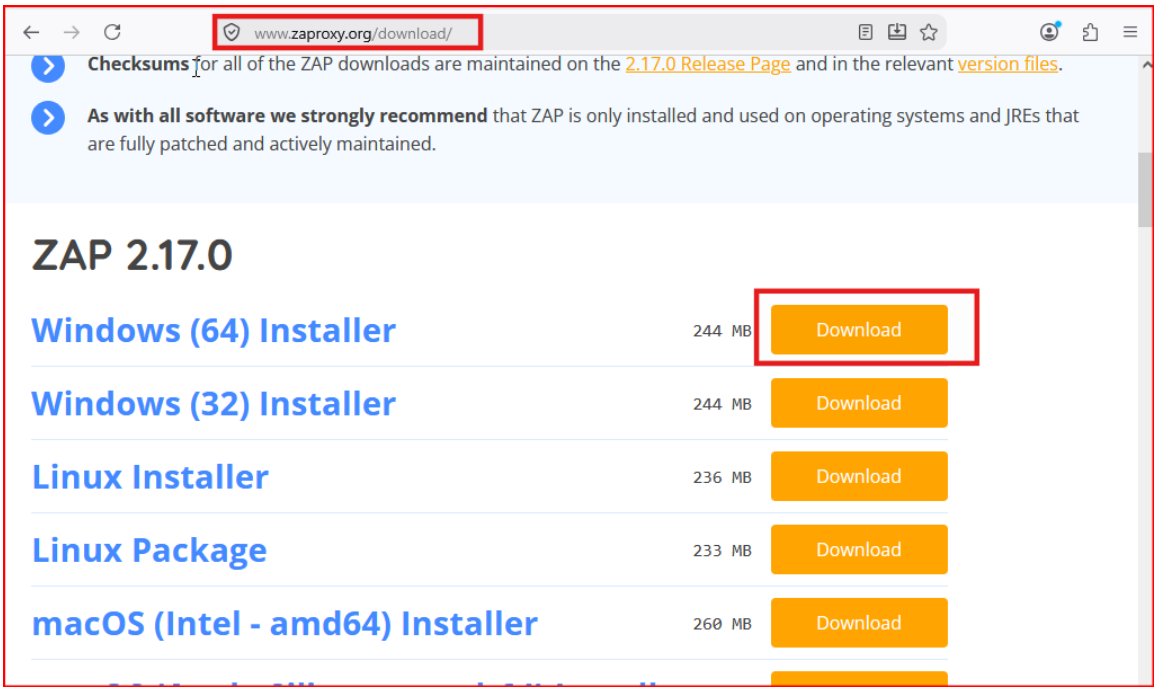
1. Start **Web Server** (192.168.100.145)
2. Start **Admin Machine** (192.168.100.138)
3. Login to both machines.

Important: Make sure the LuxuryTreats website is running on the Web Server (You can test by opening http://192.168.100.145 in a browser).



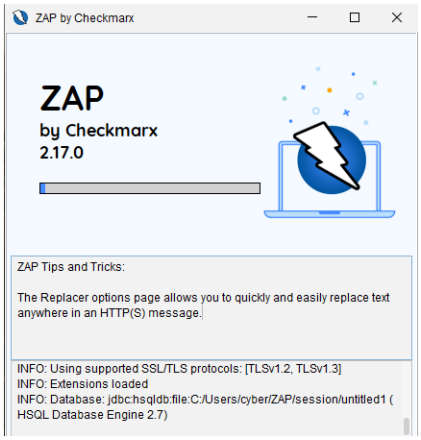
Setup & Install OWASP ZAP

install OWASP ZAP

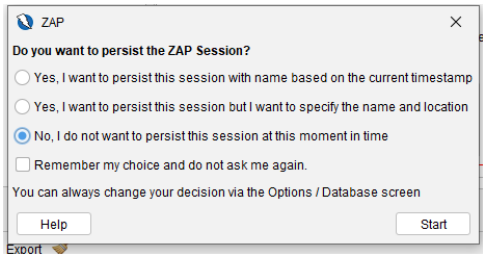


Launch OWASP ZAP

1. On the **Admin Machine**, double-click the **OWASP ZAP** icon on the Desktop.
2. If Windows Protected your PC appears → click **Run anyway**.

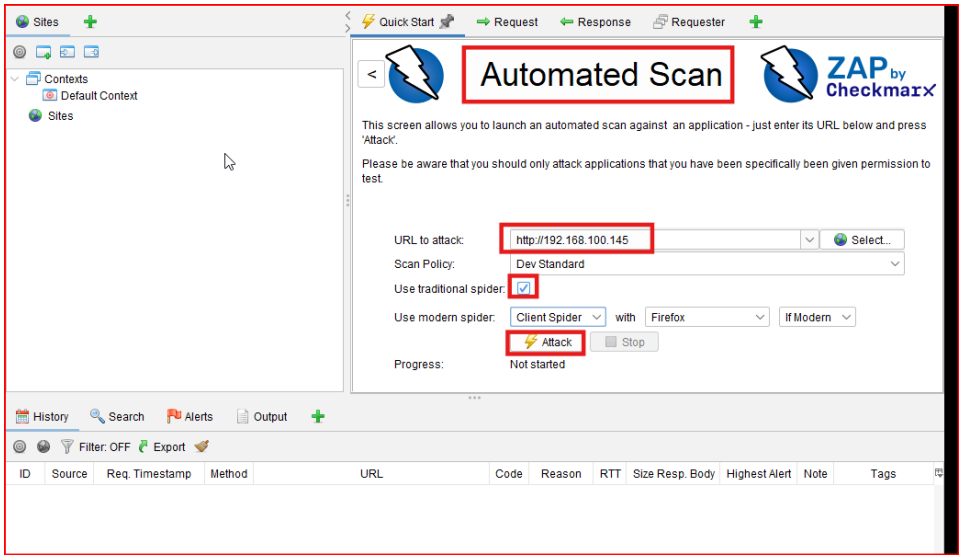


3. When the session dialog appears, select: **No, I do not want to persist this session at this moment in time**
4. Click **Start**.



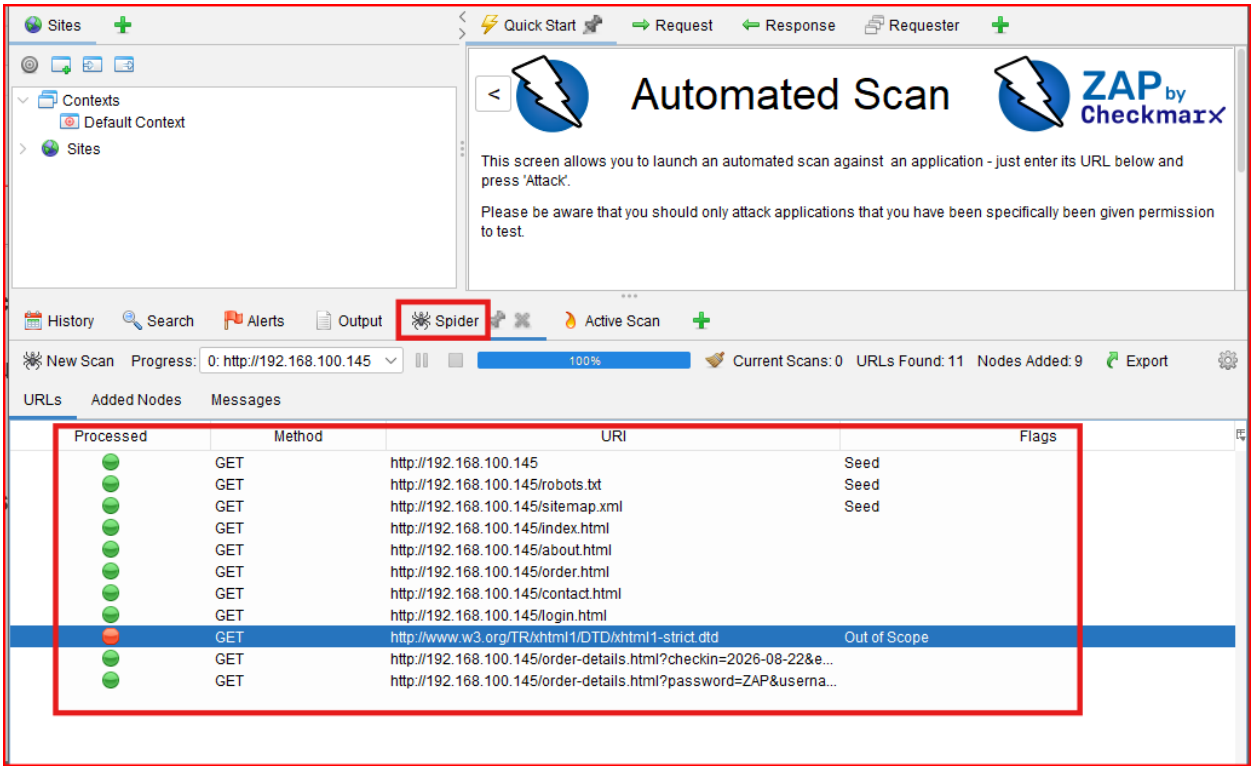
Perform Automated Scan

1. In the main ZAP window, click the **Automated Scan** option (or the big "Attack" button area).
2. In the **URL to attack** field, enter one of the following:
    - http://192.168.100.145 **or**
    - http://luxurytreats.com (if you have hosts file entry)
3. Keep **Use traditional spider** checked.
4. Click the **Attack** button.
5. Wait until the scan finishes (Progress will show "Not started" → "Actively scanning" → finished).

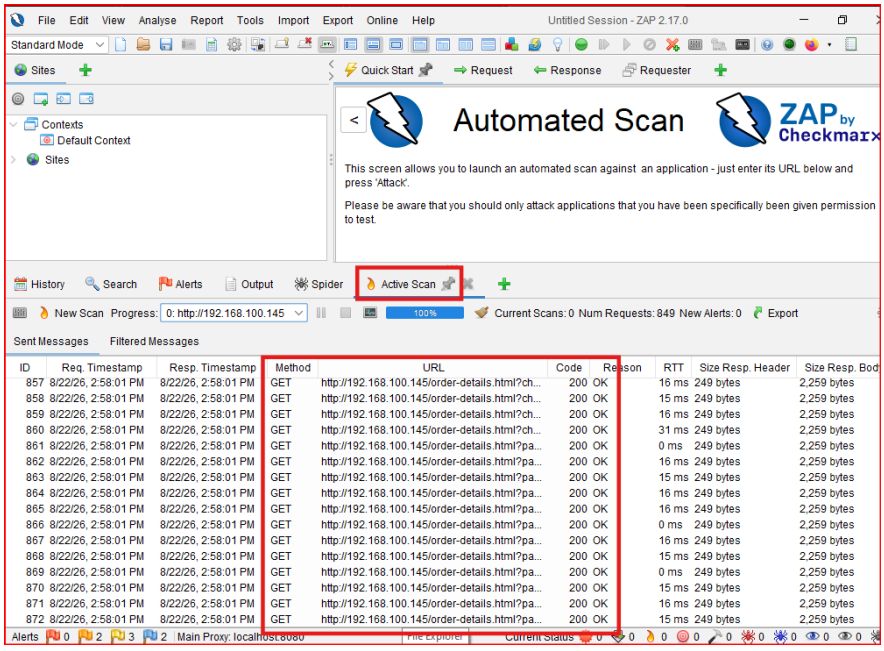


Review Spider and Active Scan Results

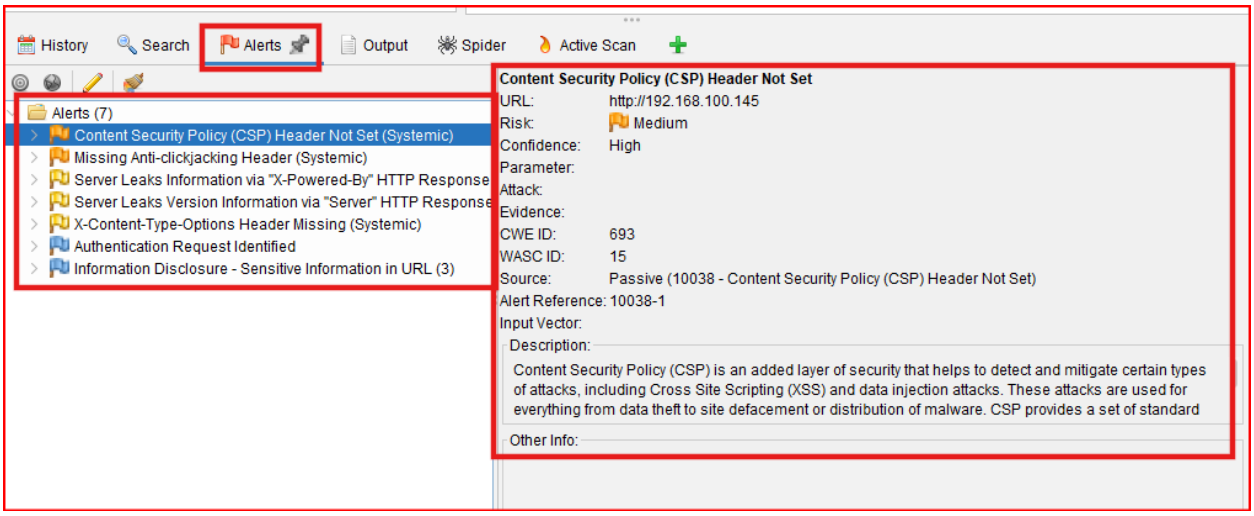
1. Click the **Spider** tab → You will see all the pages/URLs discovered on the website.



2. Click the **Active Scan** tab → You will see the active scanning progress and requests.

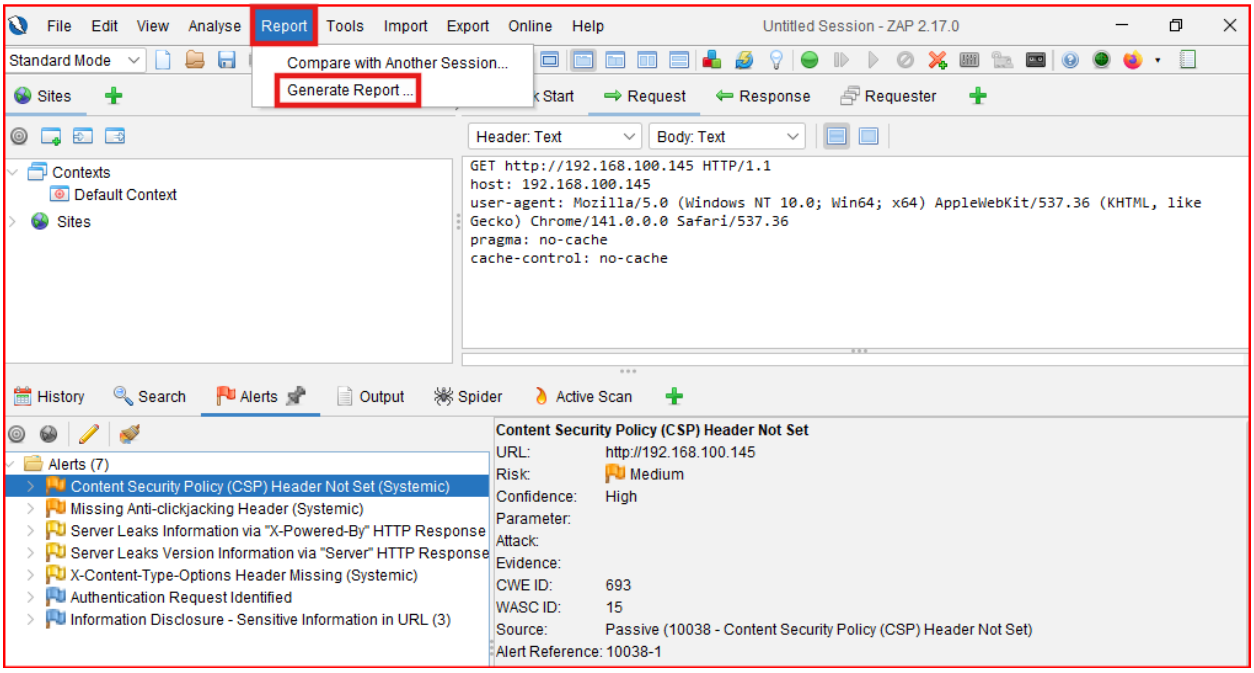


3. Click the **Alerts** tab → This shows all the vulnerabilities found (High, Medium, Low, Informational).
4. Click on any alert (example: Content Security Policy Header Not Set) to view detailed description, risk, and solution.

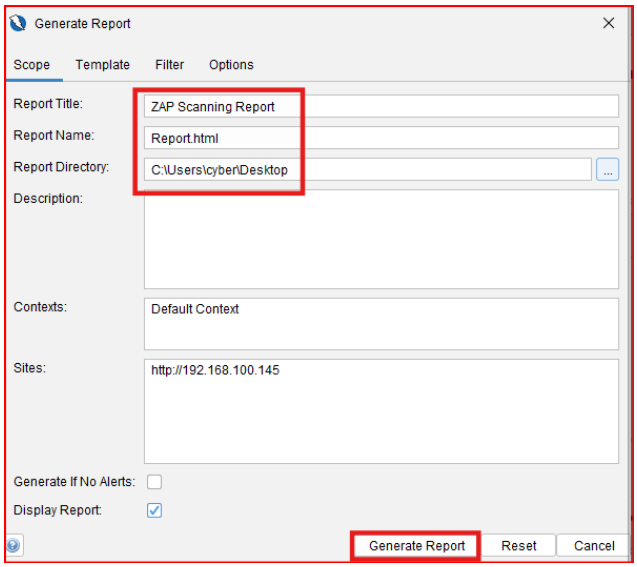


Generate Report

1. Go to the top menu: **Report → Generate Report...**



2. In the Generate Report window:
    - Report Title: ZAP Scanning Report
    - Report Name: Report.html
    - Report Directory: Choose Desktop
3. Click **Generate Report**.



4. The HTML report will open in your browser. Review the findings.



You have successfully performed Application Vulnerability Scanning using OWASP ZAP.

Key Achievements:

- Launched an automated scan against the LuxuryTreats website
- Discovered application pages using the Spider
- Identified security vulnerabilities through Active Scan and Alerts
- Generated a professional HTML vulnerability report

This demonstrates how a security professional uses a free and powerful DAST tool (OWASP ZAP) to find weaknesses in web applications before attackers do.

Vulnerability Management of Windows Server using OpenSCAP

(Risk Anticipation with Risk Management)

OpenSCAP + SCAP Compliance Checker (SCC) to perform a security compliance assessment (STIG benchmark) on the Windows Server (Web Server) and view the detailed vulnerability/compliance report.

Objective:

Install OpenSCAP and SCAP Compliance Checker

Download Windows Server STIG Benchmark

Run a Local Scan against the Web Server

View compliance score and findings by severity

Open the detailed HTML report

Use STIG Viewer (optional but recommended)

Machines Required

Machine	IP Address	Role
Web Server	192.168.100.145	Target + Run OpenSCAP / SCC

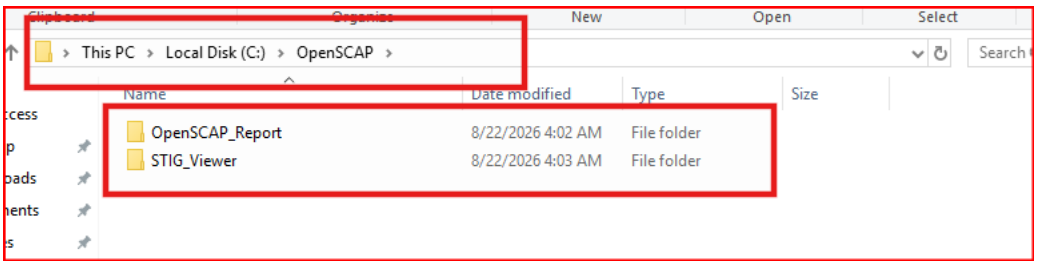
Note: This lab is performed **on the Web Server** itself (not on Admin Machine).

Tools Required

Tool	Purpose
OpenSCAP	SCAP framework
SCAP Compliance Checker (SCC)	Runs the STIG compliance scan
STIG Viewer	Views detailed STIG rules (optional)

Prepare the Web Server

1. Start the **Web Server** (192.168.100.145).
2. Login as **Administrator** / admin@123.
3. Create a folder: C:\OpenSCAP
4. Inside it create two more folders:
    - C:\OpenSCAP\OpenSCAP_Report
    - C:\OpenSCAP\STIG_Viewer



Download Required Files

On the Web Server, open a browser and download the following:

1. **Microsoft Windows Server 2019 STIG SCAP Benchmark**

👉 https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_Server_2019_V3R6_STIG_SCAP_1-3_Benchmark.zip

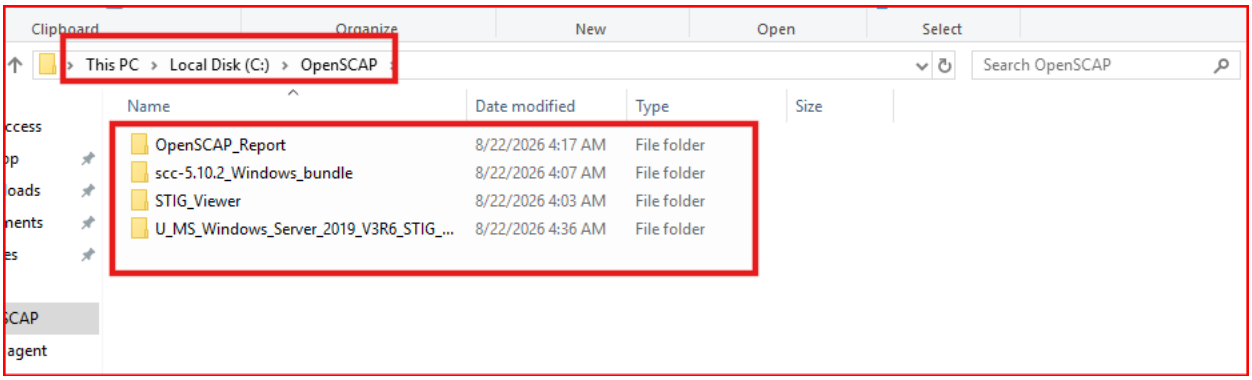
2. Download **SCC** (SCAP Compliance Checker) for Windows (latest version).

👉 https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/scc-5.10.2_Windows_bundle.zip

Extract the Files

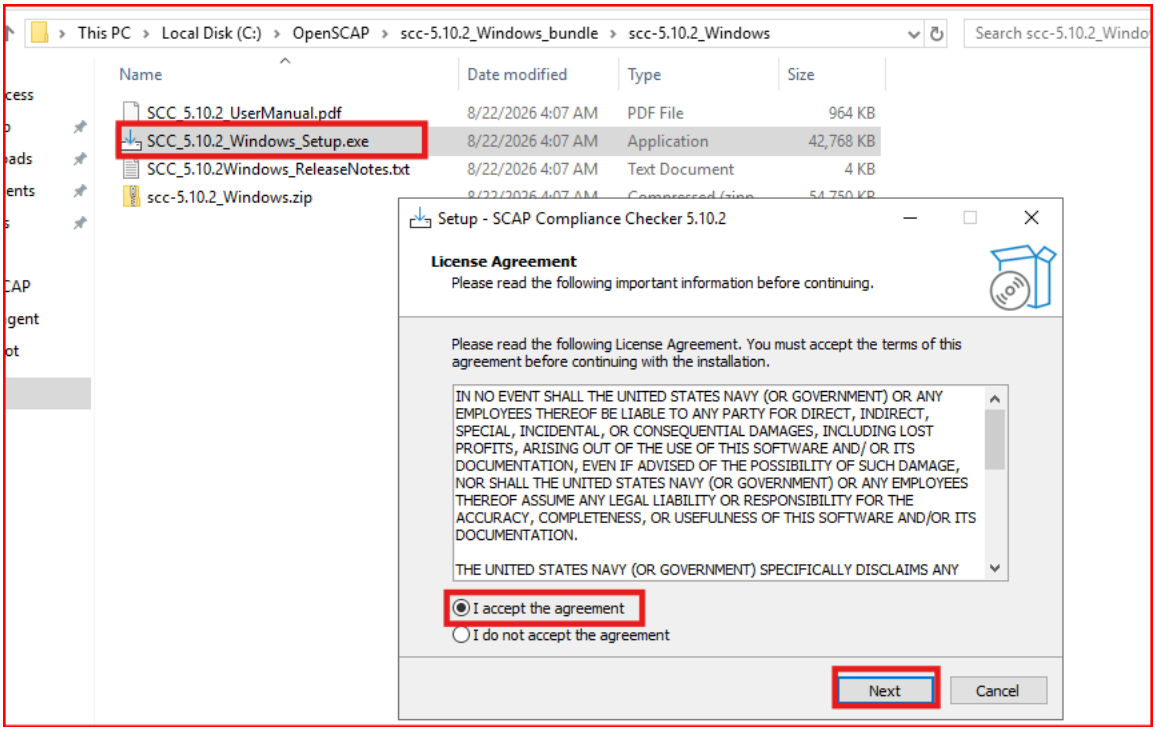
1. Extract the **SCC** ZIP file.
2. Extract the **Windows Server 2019 STIG SCAP Benchmark** ZIP file.
3. Move / copy both extracted folders into C:\OpenSCAP.

Your folder structure should look like this:



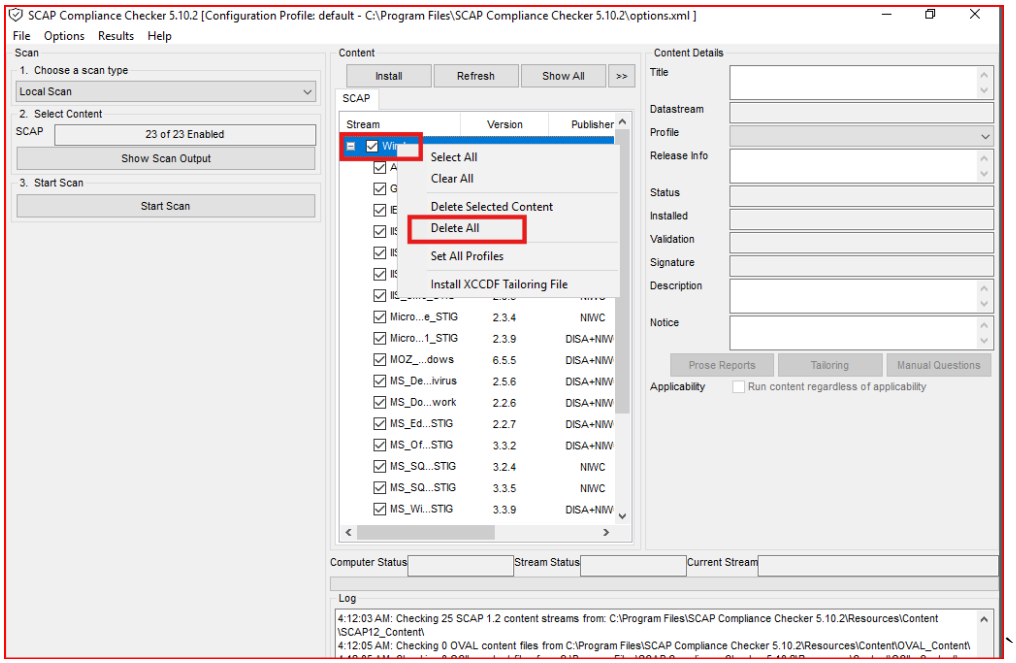
Install SCAP Compliance Checker (SCC)

1. Go to the extracted SCC folder.
2. Right-click SCC-x.x.x_Windows_Setup.exe → **Run as administrator**.
3. Accept the license → Next → Install (create desktop shortcut).
4. Finish the installation.

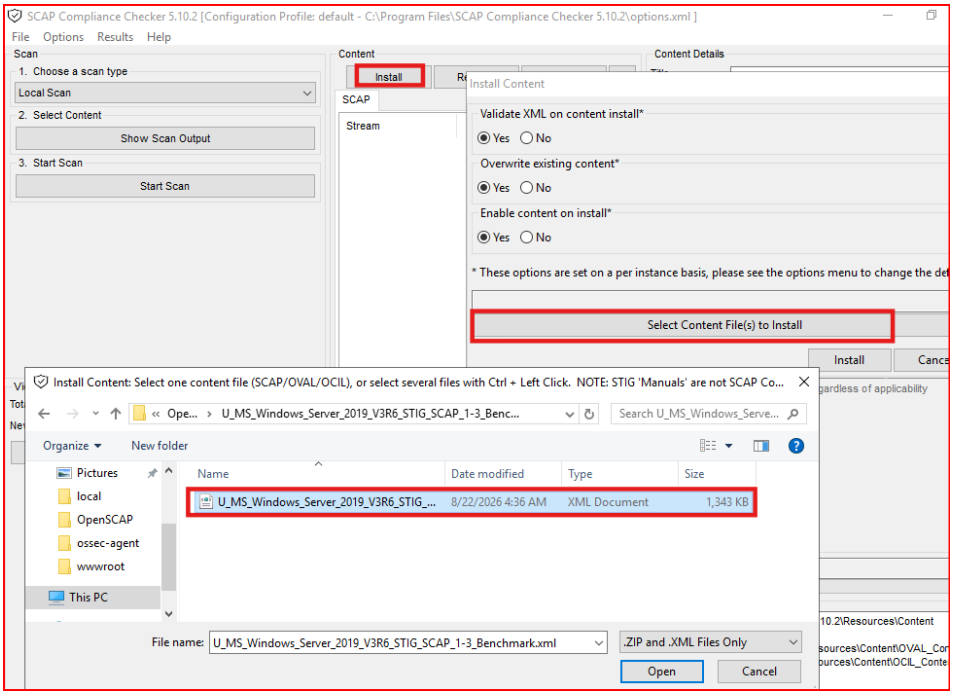


Configure and Run the Scan

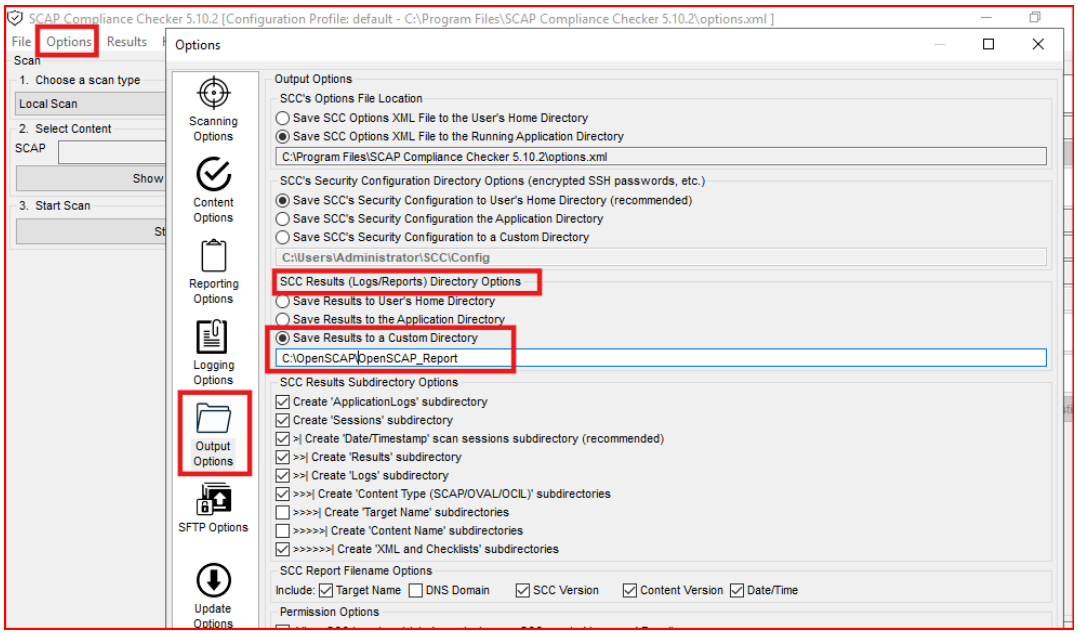
1. Launch **SCAP Compliance Checker** from Desktop.
2. In the Content section → Right-click **Windows → Delete All**.



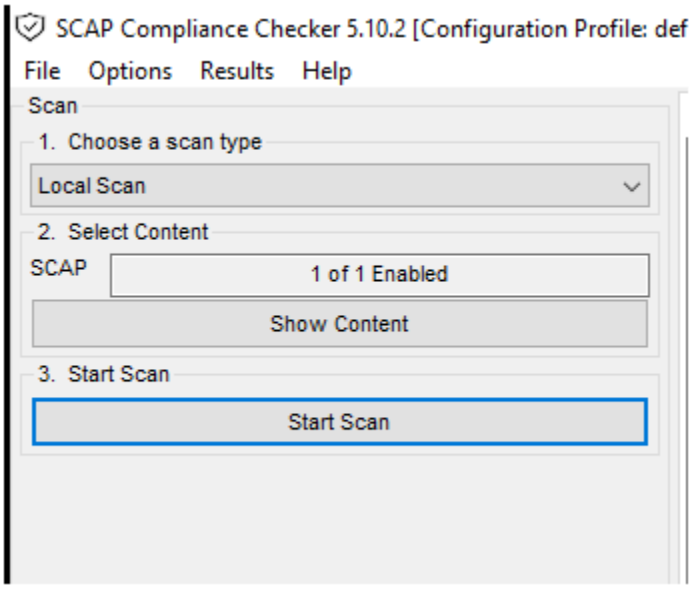
3. Click **Install → Select Content(s) to Install**.
4. Browse to the STIG Benchmark XML file you downloaded and select it → Install.



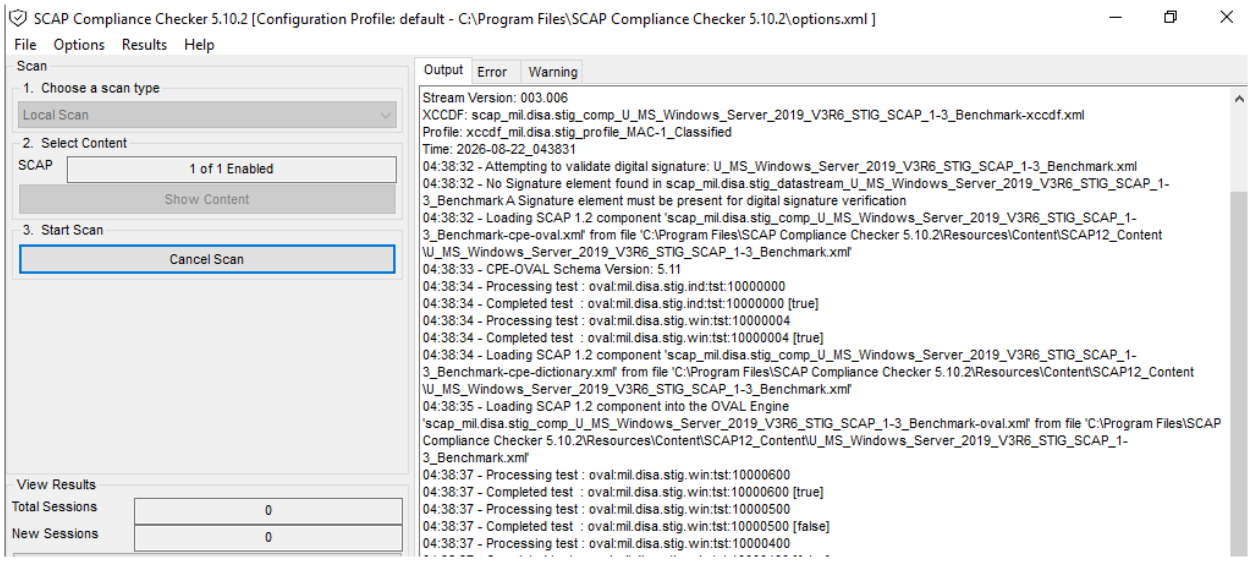
5. Go to **Options → Show Options → Output Options**.
6. Under "SCC Results (Logs/Reports) Directory Options" set the path to: C:\OpenSCAP\OpenSCAP_Report
7. Click **Save**.



8. Click **Start Scan**.

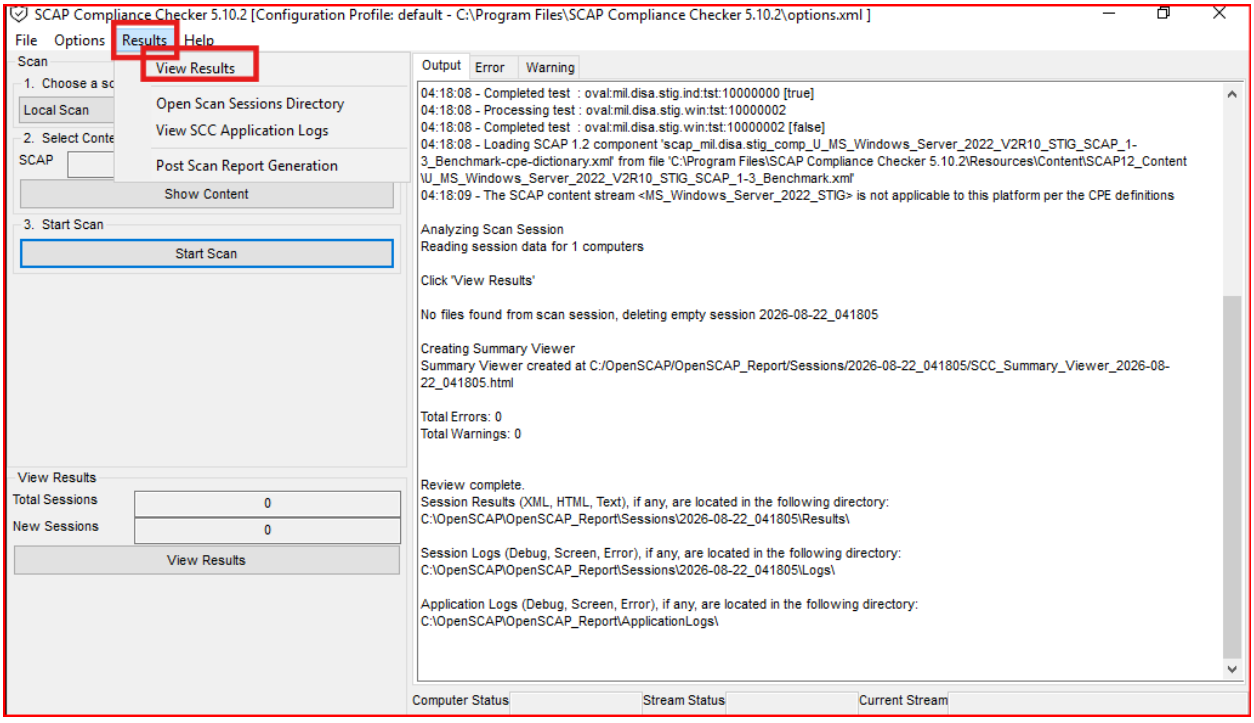


9. Wait until the scan finishes (it can take several minutes).

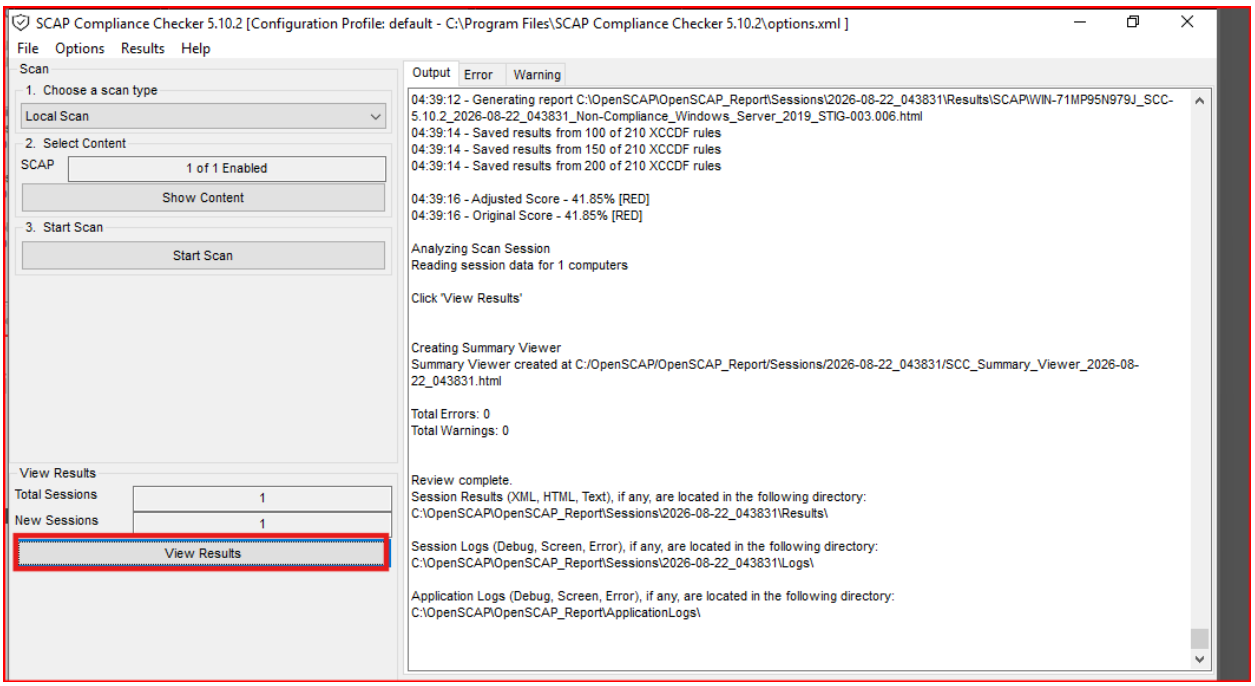


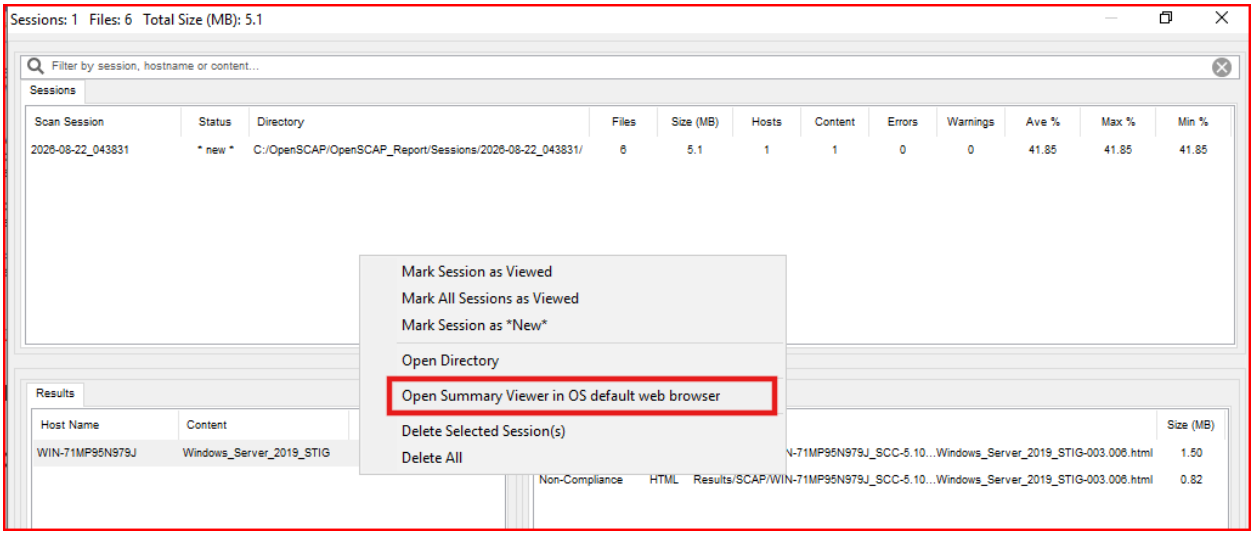
View the Results

1. Click **View Results**.

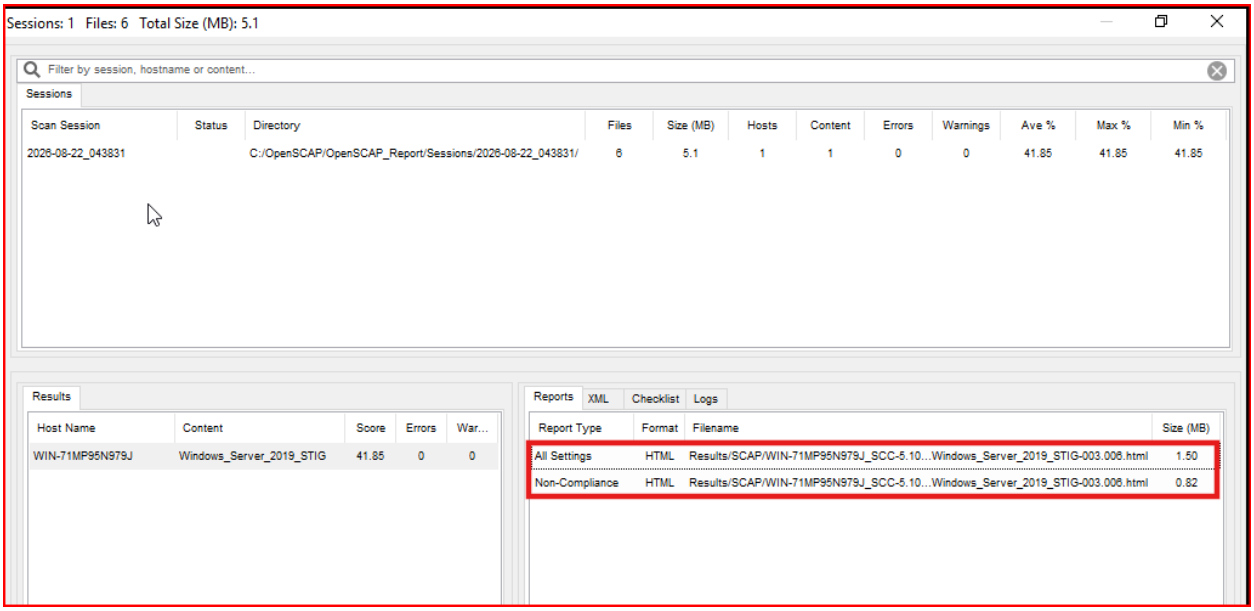


2. Right-click the scan session → **Open Summary Viewer in OS default Web Browser**.

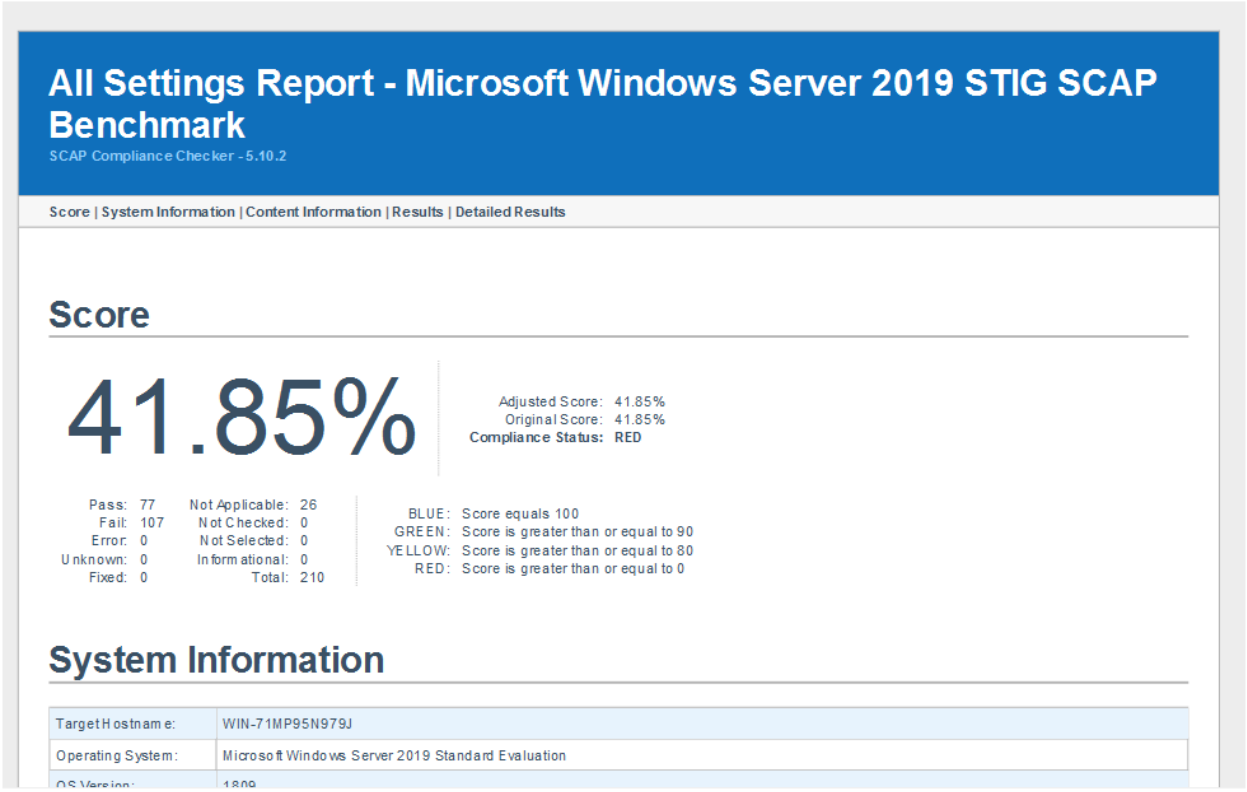




3. Click the **HTML** link under "All Settings".



4. Review the compliance score and findings categorized by severity (High / Medium / Low).



Results: High Severity (CAT I)

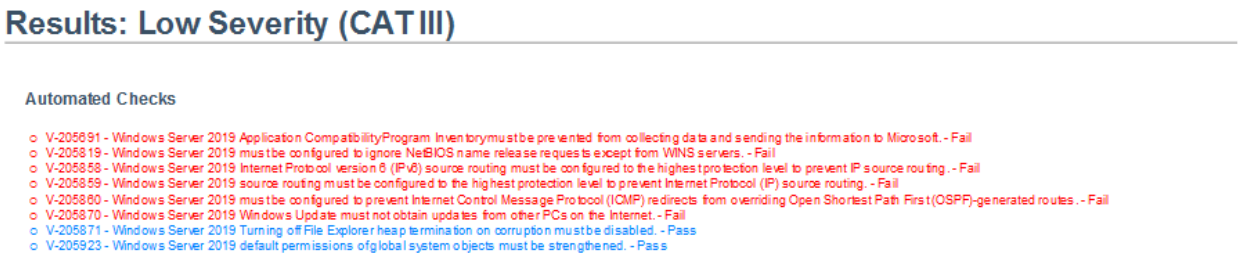
Automated Checks

- V-205653 - Windows Server 2019 reversible password encryption must be disabled. - Pass
- V-205654 - Windows Server 2019 must be configured to prevent the storage of the LAN Manager hash of passwords. - Pass
- V-205663 - Windows Server 2019 local volumes must use a format that supports NTFS attributes. - Pass
- V-205711 - Windows Server 2019 Windows Remote Management (WinRM) client must not use Basic authentication. - Fail
- V-205713 - Windows Server 2019 Windows Remote Management (WinRM) service must not use Basic authentication. - Fail
- V-205724 - Windows Server 2019 must not allow anonymous enumeration of shares. - Fail
- V-205725 - Windows Server 2019 must restrict anonymous access to Named Pipes and Shares. - Pass
- V-205739 - Windows Server 2019 permissions on the Active Directory data files must only allow System and Administrators access. - Not Applicable
- V-205750 - Windows Server 2019 Act as part of the operating system user right must not be assigned to any groups or accounts. - Pass
- V-205753 - Windows Server 2019 Create a token object user right must not be assigned to any groups or accounts. - Pass
- V-205757 - Windows Server 2019 Debug programs user right must only be assigned to the Administrators group. - Pass
- V-205802 - Windows Server 2019 must disable the Windows Installer Always install with elevated privileges option. - Fail
- V-205804 - Windows Server 2019 Autoplay must be turned off for non-volume devices. - Fail
- V-205805 - Windows Server 2019 default AutoRun behavior must be configured to prevent AutoRun commands. - Fail
- V-205806 - Windows Server 2019 AutoPlay must be disabled for all drives. - Fail
- V-205849 - Windows Server 2019 must be maintained at a supported servicing level. - Pass
- V-205908 - Windows Server 2019 must prevent local accounts with blank passwords from being used from the network. - Pass
- V-205914 - Windows Server 2019 must not allow anonymous enumeration of Security Account Manager (SAM) accounts. - Pass
- V-205919 - Windows Server 2019 LAN Manager authentication level must be configured to send NTLMv2 response only and to refuse LM and NTLM. - Fail

Results: Medium Severity (CAT II)

Automated Checks

- V-205625 - Windows Server 2019 must be configured to audit Account Management - Security Group Management successes. - Pass
- V-205626 - Windows Server 2019 must be configured to audit Account Management - User Account Management successes. - Pass
- V-205627 - Windows Server 2019 must be configured to audit Account Management - User Account Management failures. - Pass
- V-205628 - Windows Server 2019 must be configured to audit Account Management - Computer Account Management successes. - Not Applicable
- V-205629 - Windows Server 2019 must have the number of allowed bad logon attempts configured to three or less. - Fail
- V-205630 - Windows Server 2019 must have the period of time before the bad logon counter is reset configured to 15 minutes or greater. - Fail
- V-205633 - Windows Server 2019 machine inactivity limit must be set to 15 minutes or less, locking the system with the screen saver. - Fail
- V-205634 - Windows Server 2019 must be configured to audit logon successes. - Pass
- V-205635 - Windows Server 2019 must be configured to audit logon failures. - Pass
- V-205636 - Windows Server 2019 Remote Desktop Services must require secure Remote Procedure Call (RPC) communications. - Fail
- V-205637 - Windows Server 2019 Remote Desktop Services must be configured with the client connection encryption set to High Level. - Fail
- V-205638 - Windows Server 2019 command line data must be included in process creation events. - Fail
- V-205639 - Windows Server 2019 PowerShell script block logging must be enabled. - Fail
- V-205640 - Windows Server 2019 permissions for the Application event log must prevent access by non-privileged accounts. - Pass
- V-205641 - Windows Server 2019 permissions for the Security event log must prevent access by non-privileged accounts. - Pass
- V-205642 - Windows Server 2019 permissions for the System event log must prevent access by non-privileged accounts. - Pass
- V-205643 - Windows Server 2019 Manage auditing and security log user right must only be assigned to the Administrators group. - Fail
- V-205644 - Windows Server 2019 must force audit policy subcategory settings to override audit policy category settings. - Fail
- V-205648 - Windows Server 2019 must have the DoD Root Certificate Authority (CA) certificates installed in the Trusted Root Store. - Fail
- V-205649 - Windows Server 2019 must have the DoD Interoperability Root Certificate Authority (CA) cross-certificates installed in the Untrusted Certificates Store on unclassified systems. - Fail
- V-205650 - Windows Server 2019 must have the US DoD CCEB Interoperability Root CA cross-certificates in the Untrusted Certificates Store on unclassified systems. - Fail
- V-205651 - Windows Server 2019 users must be required to enter a password to access private keys stored on the computer. - Fail
- V-205652 - Windows Server 2019 must have the built-in Windows password complexity policy enabled. - Pass
- V-205655 - Windows Server 2019 unencrypted passwords must not be sent to third-party Server Message Block (SMB) servers. - Pass
- V-205656 - Windows Server 2019 minimum password age must be configured to at least one day. - Fail
- V-205659 - Windows Server 2019 maximum password age must be configured to 60 days or less. - Pass
- V-205660 - Windows Server 2019 password history must be configured to 24 passwords remembered. - Fail
- V-205662 - Windows Server 2019 minimum password length must be configured to 14 characters. - Fail
- V-205665 - Windows Server 2019 Access this computer from the network user right must only be assigned to the Administrators, Authenticated Users, and Enterprise Domain Controllers groups on domain controllers. - Not Applicable
- V-205666 - Windows Server 2019 Allow log on through Remote Desktop Services user right must only be assigned to the Administrators group on domain controllers. - Not Applicable
- V-205667 - Windows Server 2019 Deny access to this computer from the network user right on domain controllers must be configured to prevent unauthenticated access. - Not Applicable
- V-205668 - Windows Server 2019 Deny log on as a batch job user right on domain controllers must be configured to prevent unauthenticated access. - Not Applicable
- V-205669 - Windows Server 2019 Deny log on as a service user right must be configured to include no accounts or groups (blank) on domain controllers. - Not Applicable
- V-205670 - Windows Server 2019 Deny log on locally user right on domain controllers must be configured to prevent unauthenticated access. - Not Applicable
- V-205671 - Windows Server 2019 "Access this computer from the network" user right must only be assigned to the Administrators and Authenticated Users groups on domain-joined member servers and standalone or nondomain-joined systems. - Fail
- V-205672 - Windows Server 2019 "Deny access to this computer from the network" user right on domain-joined member servers must be configured to prevent access from highly privileged domain accounts and local accounts and from unauthenticated access on all systems. - Fail
- V-205673 - Windows Server 2019 "Deny log on as a batch job" user right on domain-joined member servers must be configured to prevent access from highly privileged domain accounts and from unauthenticated access on all systems. - Fail



Successfully performed a security compliance assessment of the Windows Server using OpenSCAP / SCAP Compliance Checker.

Key Achievements:

- Installed and configured SCAP Compliance Checker
- Imported Windows Server STIG Benchmark
- Ran a full local compliance scan
- Generated and reviewed a detailed HTML compliance report with severity levels

This demonstrates how a network defender uses open-source SCAP tools to check systems against official security baselines (STIGs) and identify configuration weaknesses.

Vulnerability Analysis Using the Nessus

(Risk Anticipation with Risk Management)

Using **Nessus** to perform a comprehensive vulnerability scan on the Web Server, create a custom scan policy, run the scan, analyze the findings, and generate a detailed report.

Objective:

Access Nessus web interface

Create a custom Advanced Scan policy

Configure credentials for authenticated scanning

Launch a vulnerability scan against the Web Server

Analyze vulnerabilities by severity

Generate and view a detailed HTML report

Machines Required

Machine	IP Address	Role
Admin Machine	192.168.100.138	Nessus Scanner
Web Server	192.168.100.145	Target to be scanned

Tools Required

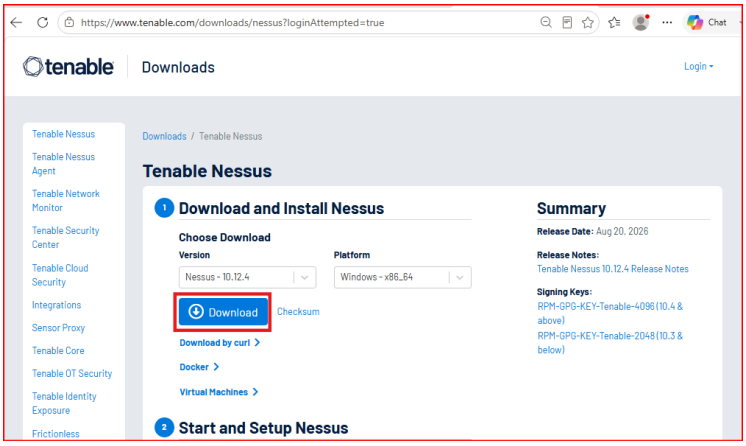
Tool	Purpose
Nessus	Vulnerability Scanner
Browser	Access Nessus web interface

Launch Machines

1. Start **Admin Machine** (192.168.100.138)
2. Start **Web Server** (192.168.100.145)

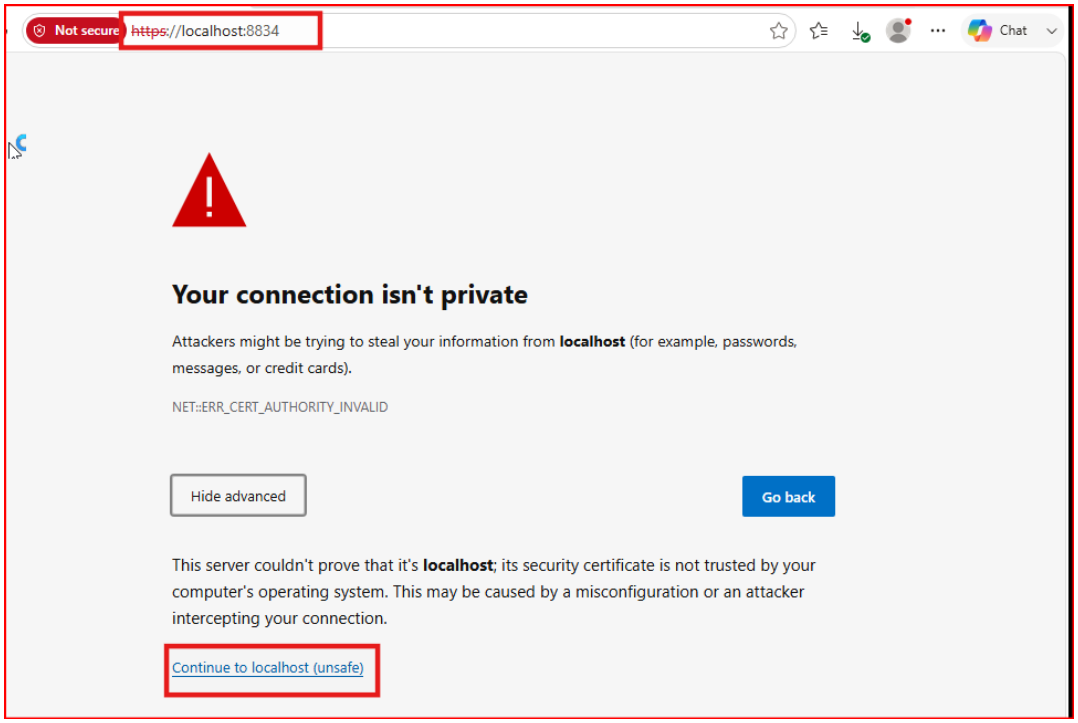
Download Nessus (If not available)





Access Nessus

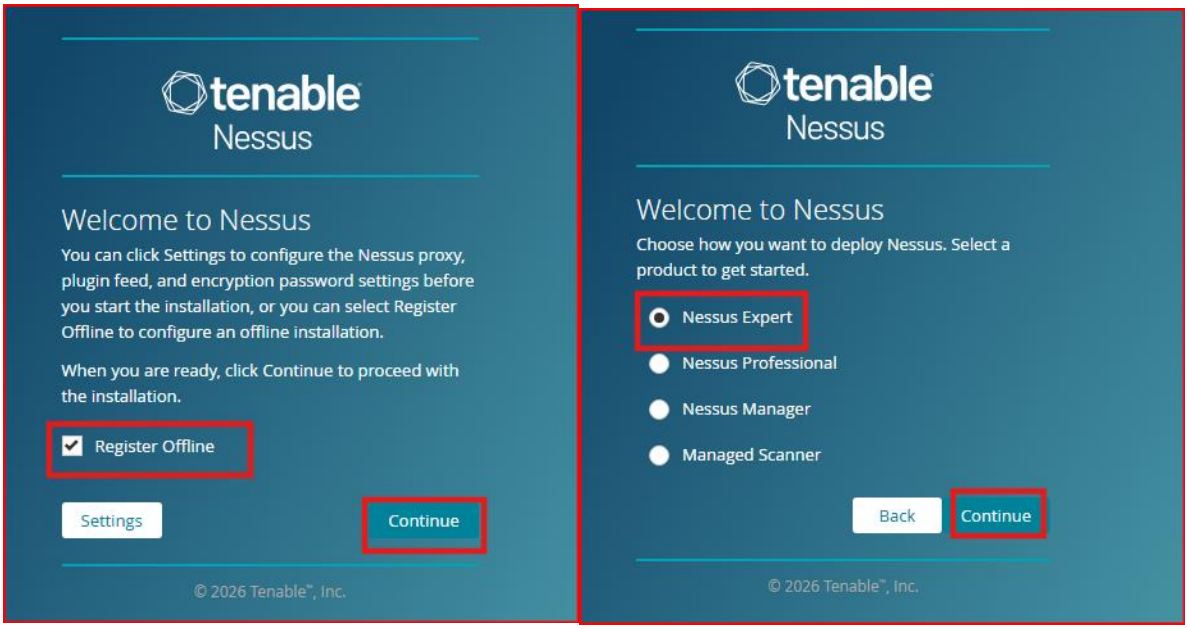
1. On **Admin Machine**, open Google Chrome.
2. Go to: https://localhost:8834
3. Click **Advanced → Proceed to localhost (unsafe)**.



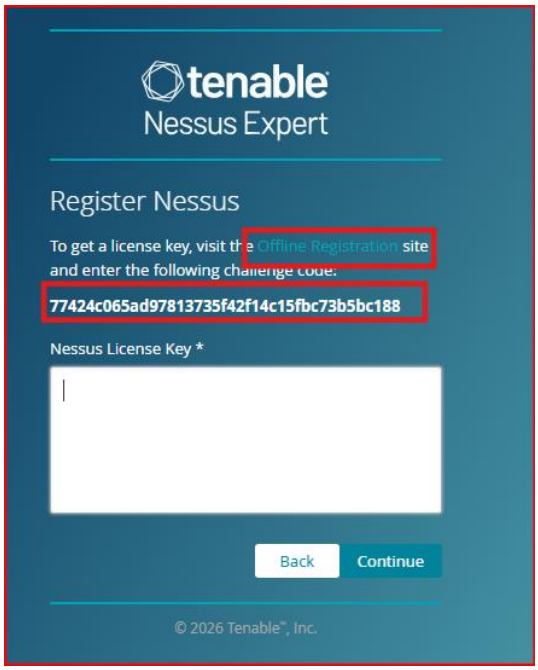
4. Connect with SSL



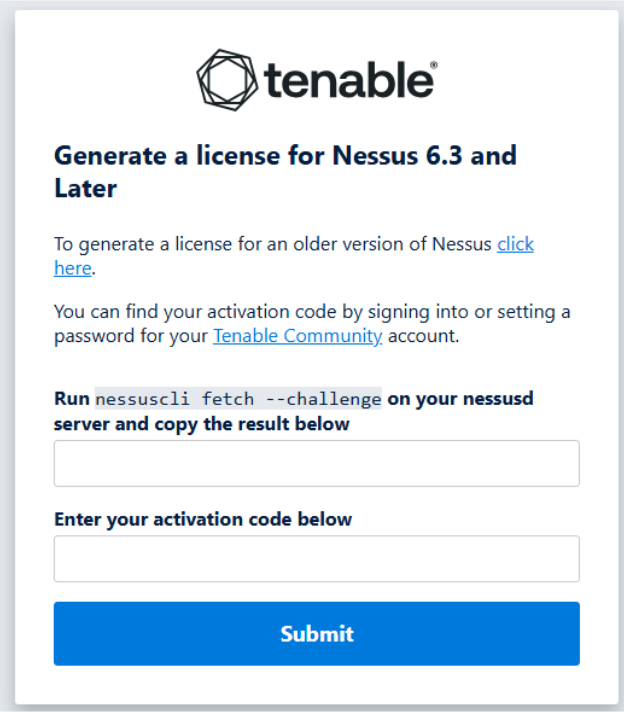
Select Offline Register -> Continue



Copy the code and save it for later:



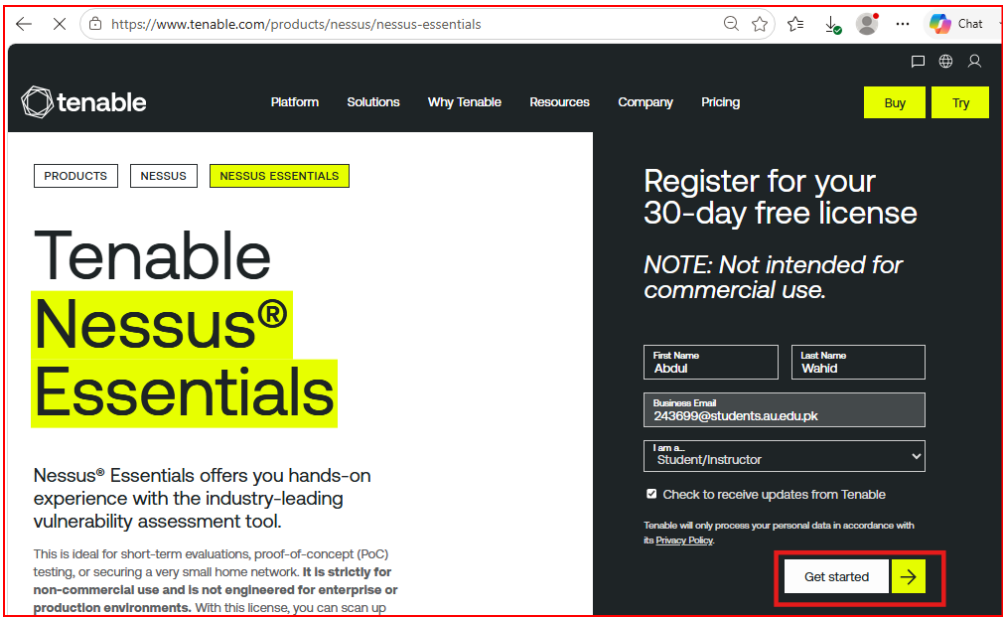
We want Activation code here: (Don't close this window-> Proceed next step)



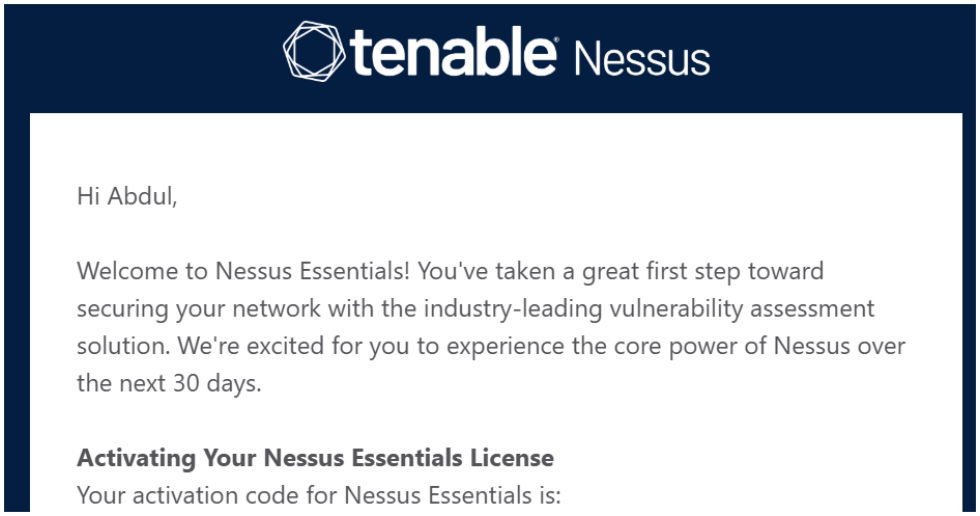
On your **host machine** (or any machine with internet), open a browser and go to this link:

👉 https://www.tenable.com/products/nessus/nessus-essentials

Click **Register** or **Get Started** and create a free account (or login if you already have one).



Check your mail



After registration, Tenable will give you a **free Activation Code** (it looks like this: XXXX-XXXX-XXXX-XXXX).

Now go back to the screen you showed (the second image).

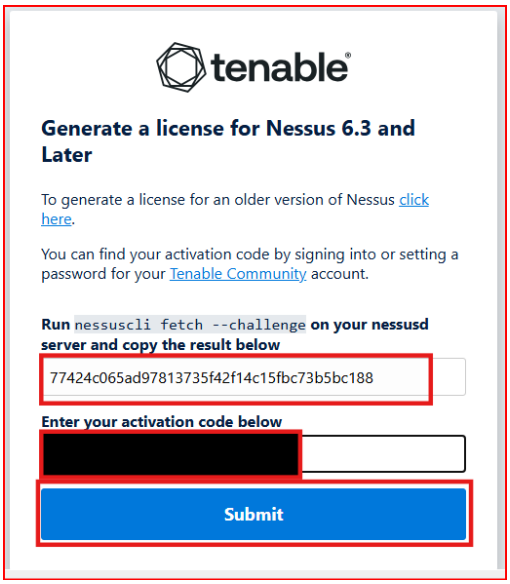
Click on the blue link: **Offline Registration site**

On the new page:

Paste the **Challenge Code** you see in your Nessus window: 77424c065ad97813735f42f14c15fbc73b5bc188

Paste the **Activation Code** you received from Tenable

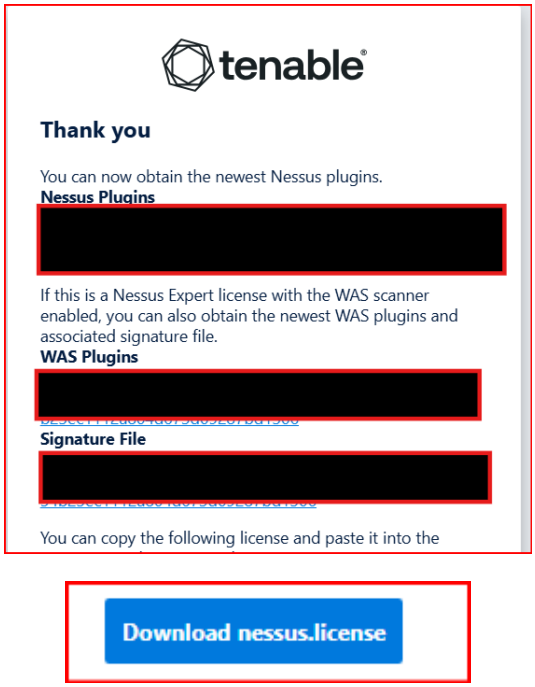
Click **Submit**



Tenable will give you a **License Key**.

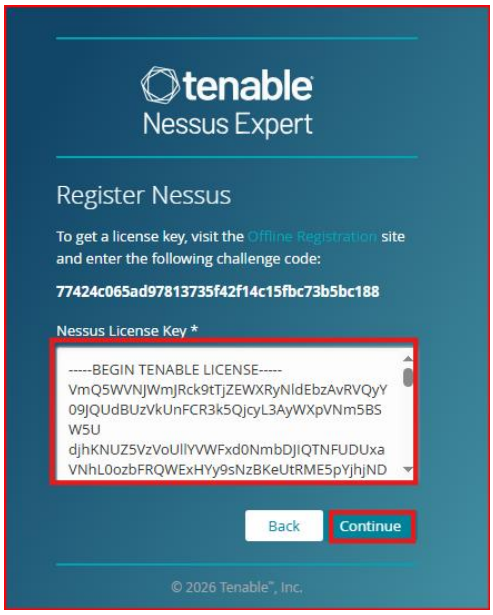
Make sure to add plugins & signatures (will be used soon)

Click on the link to install Plugins and signature files

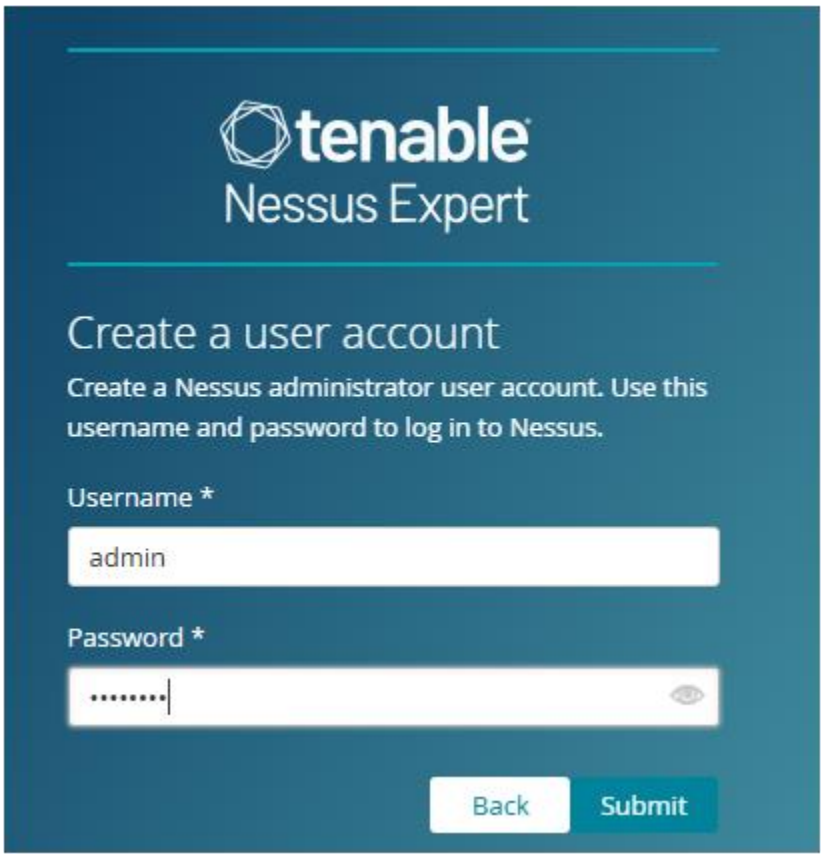


Copy that License Key and paste it into the **Nessus License Key** field in your Nessus window.

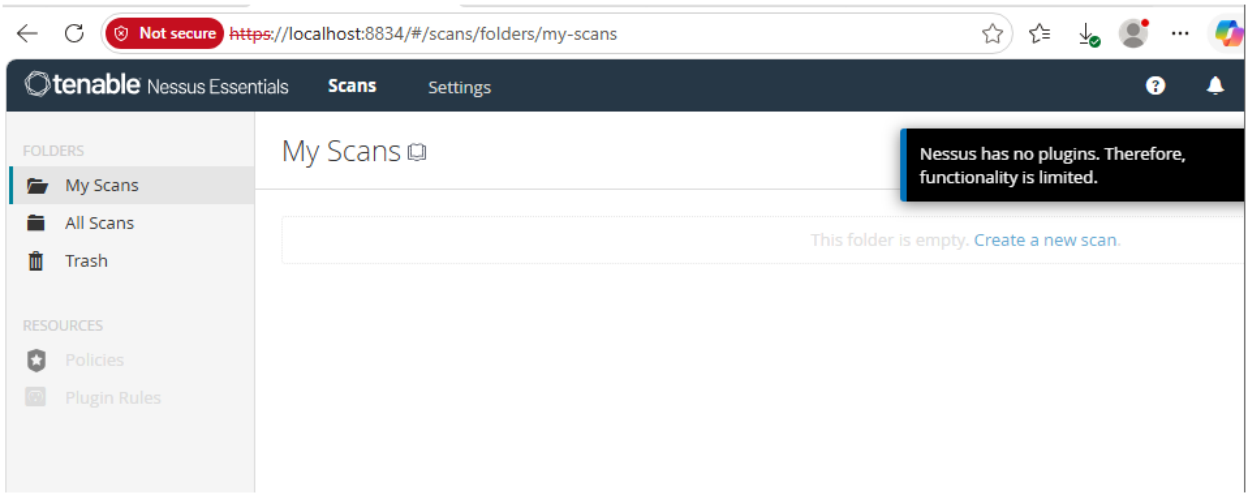
Click **Continue**.



5. Login with:
    - Username: admin
    - Password: Admin123



6. If a "Welcome to Nessus Essentials" popup appears → click **Close**.

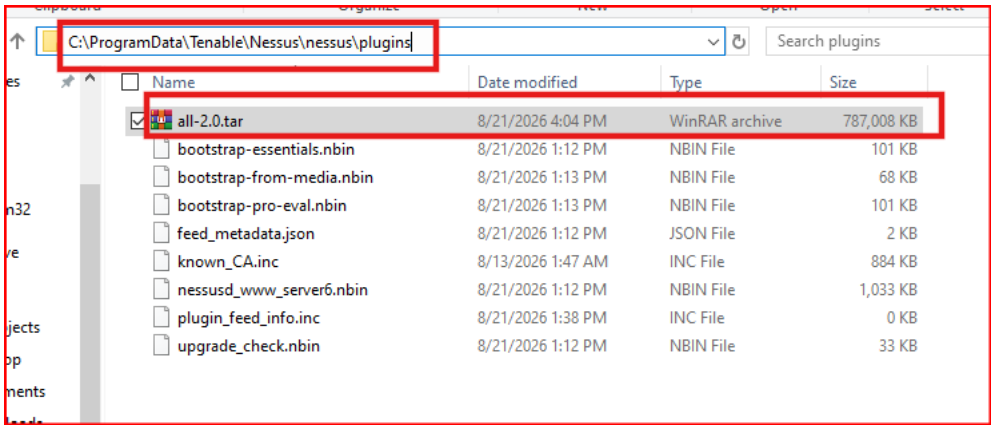


Install Plugins Manually

1. On your **Admin Machine**, open **File Explorer**.
2. Go to the folder where you downloaded the plugins (you have these files):
    - all-2.0.tar.gz ← **This is the main one we need**
    - plugins-was.tar.gz
    - plugins-was.tar.gz.sig
3. **Copy** the file all-2.0.tar.gz.
4. Paste it into this folder on the Admin Machine:

C:\ProgramData\Tenable\Nessus\nessus\plugins

(If the plugins folder does not exist, create it.)

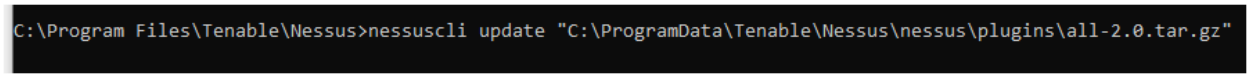


5. Now open **Command Prompt as Administrator** and run these commands one by one:

cd "C:\Program Files\Tenable\Nessus"



nessuscli update "C:\ProgramData\Tenable\Nessus\nessus\plugins\all-2.0.tar.gz"



6. Wait until the update finishes (it can take 10–20 minutes).
7. After it finishes, restart the Nessus service:

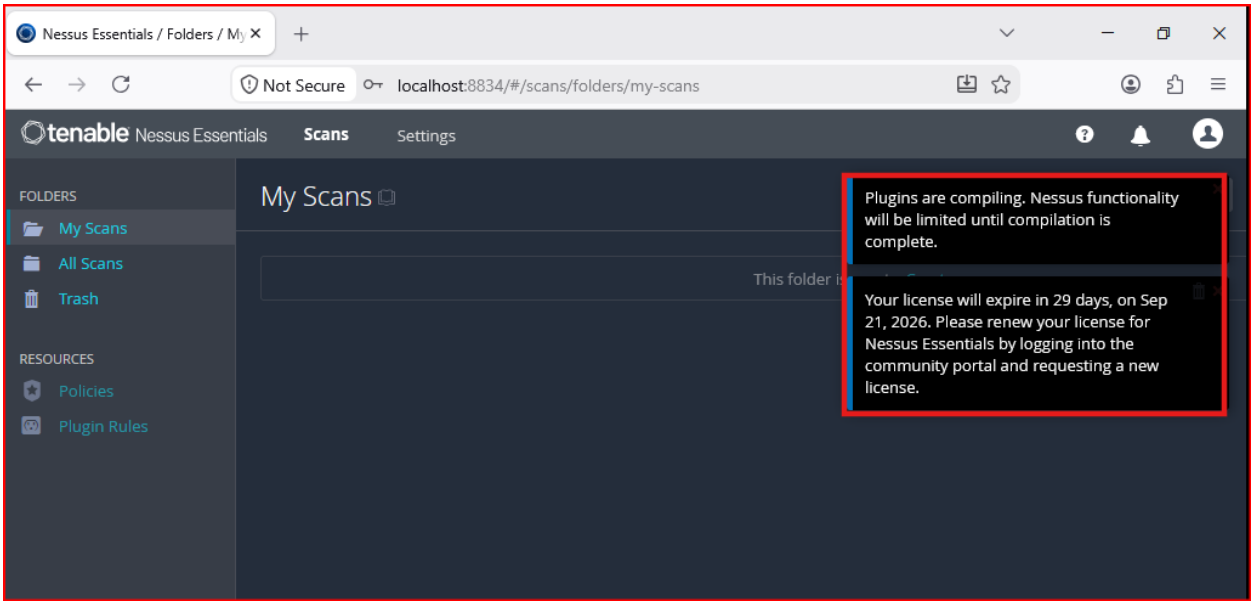
net stop "Tenable Nessus"

net start "Tenable Nessus"

```
C:\Windows\system32>net stop "Tenable Nessus"
The Tenable Nessus service is stopping..
The Tenable Nessus service was stopped successfully.


C:\Windows\system32>net start "Tenable Nessus"
The Tenable Nessus service is starting.
The Tenable Nessus service was started successfully.
```

8. Refresh the Nessus web page (https://localhost:8834).



INCOMPLETE DUE TO PREMIUM ACCESS

This demonstrates how a network defender uses a professional vulnerability scanner to identify, prioritize, and plan the remediation of security weaknesses in the network.

Conclusion

From the first OSSIM asset discovery to the final Nessus findings, Module 18 turned risk anticipation into a disciplined practice.

The Web Server was enrolled, monitored with HIDS, and scanned for vulnerabilities inside OSSIM. OWASP ZAP exposed application-layer weaknesses through automated spider and active scans. OpenSCAP delivered precise compliance and configuration insights, while Nessus provided professional vulnerability analysis and prioritization.

The lab is complete. Blind spots have been illuminated, risks are quantified, and the defensive posture has shifted from reactive to anticipatory. Defenders now find the weaknesses before the adversary does.